

Sri Lanka Institute of Information Technology



Group Assignment No. 01

ISO 27001 (ISMS) Implementation for an Organization

DSM IT (Pvt) Ltd

Enterprise Standards for Information Security – IE3102

B.Sc. (Hons) in Information Technology

Group Details

Project Title: ISO 27001 (ISMS) Implementation

Name	Student ID
Prasad M.M.W	IT23252868
Kumarage T.D.S.D.	IT23292918
Lahiru W.T	IT23253612
Weerakumara K.D	IT23202436

Table of Contents

1. Introduction and Overview.....	7
2. Purpose and Objectives	8
3. Scope of ISMS	9
Products and Services.....	9
4. ISMS Policy and Procedures	10
5. Roles and Responsibilities.....	12
Project Manager	13
1. Introduction and Overview.....	13
2. Key Responsibilities of the Project Manager.....	13
3. Project Planning and Timeline Management.....	13
3.1 Creating a Project Plan	13
3.2 Monitoring Progress.....	14
3.3 Adjusting the Plan	14
4. Budget Oversight.....	15
4.1 Resource Allocation	15
5. Coordination and Communication Among Team Members.....	15
5.1 Coordinating Team Members.....	15
5.2 Regular Updates	16
5.3 Documentation	16
6. Creating and Maintaining Project Plans and Reports.....	16
6.1 Project Plans.....	16
6.2 Status Reports.....	16
6.3 Stakeholder Communication	17
Risk Assessment Lead	17
2. Responsibilities	17
2.1 Identify and Value of Information Assets.....	17
2.2 Threats and Vulnerability Analysis	17
2.3 Risk Assessment Methodology	18

2.4 Risk Assessments Should be Carried out on a Routine Basis	18
2.5 Risk Treatment Planning	18
2.6 Reporting and Communication	18
2.7 Causal Monitoring & Evaluation	19
3. Conducting Risk Assessments.....	19
3.1 Risk Assessment Methodology	19
3.2 Risk Assessment Process.....	19
3.3 Risk Evaluation	19
3.4 DISTINCT FORMS OF IT RISK CONSIDERATIONS	20
3.5 Risk Assessment Reporting.....	20
4. Developing Risk Treatment Plans	20
4.1 Risk Treatment Options.....	20
4.2 Control Selection.....	20
4.3 Development of Risk Treatment Plans.....	21
4.4 Implementation Planning	21
4.5 Residual Risk Assessment.....	21
4.6 Continuous Monitoring and Review	21
5. Skills and Qualifications.....	22
ISMS Policy and Procedure Developer.....	22
1. Conduct a Gap Analysis	22
1.1 Review of Existing Documentation.....	22
1.2 Assessment of Current Practices	22
1.3 Stakeholder Interviews.....	23
1.4 Technical Infrastructure Review	23
1.5 Gap Analysis Report	23
2. The following are the sub processes involved in the Development of ISMS Policy:	23
2.1 ISMS Policy Development.....	23
2.2 Supporting Procedures Creation.....	24
2.3 IT-Specific Considerations	24

2.4 Agile and Remote Work Adaptations	24
2.5 Relationship with Organizational Goals.....	24
3. The first is to Enhance Focus on Policy and Procedure Formation	25
3.1 Risk Assessment Integration	25
3.2 Compliance Requirements	25
3.3 Resource Allocation	25
3.4 Quick Wins.....	25
3.5 Dependency Mapping	26
4. Implement a Phased Roll-out.....	26
4.1 Roll-out Planning	26
4.2 Pilot Implementation	26
4.3 Communication Strategy.....	26
4.4 Technical Implementation	27
4.5 Documentation Distribution	27
5. Regularly Review and Update.....	27
5.1 Scheduled Reviews	27
5.2 Change Management.....	27
5.3 Audit Results Integration.....	28
5.4 Emerging Threat Monitoring.....	28
5.5 Regulatory Compliance.....	28
5.6 Continuous Improvement.....	28
5.7 Reorientation to align with Organizational Aims.....	28
Implementation and Compliance Officer.....	29
Security Awareness and Training Coordinator	31
Process for Creating Training Materials for ISO 27001:2022 Implementation.....	32
Types of Training Materials.....	33
Schedule for Regular Training Sessions and Refresher Courses	33
Conducting Training Sessions	34
Communicating Security Policies and Updates.....	34

Measuring the Effectiveness of the Training Program	35
Monitoring and Reporting Compliance with ISO 27001:2022 Training Requirements	35
Recommendations for Ongoing Development and Improvement.....	35
6. Risk Management Framework	36
7. Document Control and Change Management	36
8. Incident Management.....	37
9. Audit and Compliance	38
10. Continual Improvement.....	38
Risk Security Report.....	39
Introduction	39
1. Risk Assessment and Treatment Process.....	40
1.1 Criteria for Performing Information Security Risk Assessments	41
1.2 Risk Acceptance Criteria	42
2. Risk Identification and Analysis	43
2.1 Asset Inventory.....	45
2.2 Threats and Vulnerabilities.....	46
Overview	50
Maintenance and Review	50
Security Awareness and Training Plan	51
Incident Response Plan	52
Purpose and Objectives	52
Business Continuity Plan.....	53
Executive Summary	53
Scope	53
Business Impact Analysis.....	54
Testing and Validation.....	54
References	55

1. Introduction and Overview

DSM IT (Pvt) Ltd is an emerging IT solutions provider in Sri Lanka as known for software development, cloud services and IT infrastructure management. The firm's clients include companies in the banking, healthcare and retail industries, where it is crucial to protecting information to preserve customer confidence and operations. These would be such valuable assets as customer databases, private cloud applications and facilities that are supporting client's operations. Between growing demands from regulators and an escalating cyber threat environment, DSM IT realizes it's high time they further improve security in line with international standards.

The aim of this engagement is to support DSM IT in organizing and testing the deployment of an ISMS compliant with ISO/IEC 27001:2022. The ISMS will present a systematic model to control and manage risks and to provide a clear understanding of any gaps in policies and controls which exist, and determine the most appropriate treatment. This activity will also include creation of critical ISMS documentation such as scope statement, information security policy, SoA and risk treatment plan. By working towards ISO 27001, DSM IT can prove their adherence, lower the number of security incidents and become more resistant to growing risks.

The ISMS contraction will include key business areas such as IT operations, software engineering and cloud infrastructure management. Things like datacenters, intranet, and client facing systems are where the focus will be and stuff like Marketing, PR etc. won't be on the list since they don't contain much sensitive information. The ISMS will also consider dependencies with external service providers including cloud service providers and internet service providers, as they also protect essential processes.

For efficient implementation, the consulting team has assigned a cooperative allocation of roles. The project management and integration will be managed by the Lead Consultant and gap analysis and the risk register will be built by the Risk & Controls Analyst. The ISMS Documentation Specialist will work towards building policy documents, the Compliance Advisor will ensure regulatory directives are followed. And last but not least, the Presentation and Stakeholder Lead will be responsible for putting together the executive-level presentation and handle engaging stakeholders. Collectively, this structure guarantees that DSM IT is provided by full spectrum guidance according to its security requirements.

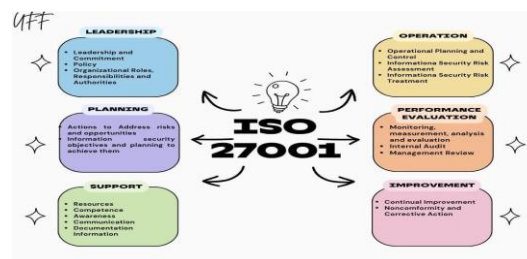
2. Purpose and Objectives

This task serves to support DSM IT (Pvt) Ltd in establishing the groundwork of an Information Security Management System (ISMS) as per ISO/IEC 27001:2022. And now, as an IT provider operating with the customer's most sensitive data and mission-critical systems, DSM IT has the responsibility to protect its own operations from unauthorized access, cybersecurity threats, or non-compliance. An ISMS, once implemented, will ensure that that organisation has a well-structured and internationally recognized way of securing their own information assets, as well as being able to demonstrate they are holding themselves to account to clients, regulators and partners.

The Sensormatic Solutions Approach Stage # 1: Gap Analysis The initial goal is to perform an extensive gap analysis that will analyze DSM IT's existing information security baseline. This is done by checking an existing process or system against the requirements of ISO 27001 and the controls from Annex A of ISO 27001, which identify whether the current process or system meets these. In turn, this will help the organization identify which areas need the most development and which can be used to their advantage when getting ready for certification.

Second is to compile the central ISMS documents, namely scope, information security policy, statement of applicability and risk treatment plan. These papers are intended to form the underpinning of DSM IT's ISMS in terms of strategy and operational guidelines. Furthermore, a risk register will be created to establish the relationship between key assets and threats, vulnerabilities and treatment options to promote a riskbased approach to security management.

The ultimate goal is to produce a board-level presentation and raise awareness of the facts and roadmap of, the benefits of carrying out ISO 27001. This will allow senior management to appreciate not only the risks, but also all the strategic advantages of an ISMS – such as regulatory compliance, customer confidence, operational resilience, and competitive advantage. Taken as a whole, the purpose and objectives will prepare DSM IT to aim for ISO 27001 certification and to create a culture of security enhancement.



3. Scope of the ISMS Implementation

The boundaries for the ISMS delineate what the ISMS is for i.e., the organization. It identifies the processes, systems and departments that are included in the ISMS, and also ensures that all attention is directed at protecting the most valuable assets. For DSM IT (Pvt) Ltd., the ISMS deployment will mainly cover IT solution Development, managed services and cloud infrastructure. Internal supports that are the business core processes and high value information.

The ISMS will be implemented on all business units that are responsible for the design development, implementation and support of IT solutions. This includes teams of software engineers, infrastructure services, information security operations, and the client support organization. Processes that are a natural part of an organization such as project management, incident response, data storage, and system administration are specifically addressed because of their direct relevance to delivering a service and gaining the trust of the customer.

Technically, the ISMS will apply to company networks, servers, cloud services, end user equipment and data centers that DSM IT operates or drives. Both on premises and cloud environments are in scope to provide consistent data protection across hybrid infrastructure. Subcontractors and third party service providers who process, transmit or store client information also fall within the ISMS framework as their activities affect the organization's risk position.

The general office facilities and personal devices that are not attached to corporate systems are out of scope, as they do not materially impact the confidentiality, integrity, or availability of the critical business data. Justification; and Documentation to keep the ISMS boundary clear of any interference.

By establishing that boundary, DSM IT (Pvt) Ltd is able to make its ISMS implementation full and efficient by focusing on the high-risk areas which need improvement and that are relevant to ISO/IEC 27001:2022 in particular requirements for continuous improvement and compliance-readiness.

4. Consulting Team Roles and Responsibilities



4.1) Lead Consultant / Project Coordinator

Lead Consultant/Project Coordinator at DSM IT (Pvt) Ltd is responsible in general for ISMS implementation simulation countermeasures. This person takes up the slack in project management and expectation management (of everybody – SOP as well as timing) DownieWorks to keep everything good quality, a good final rec that's well written and well presented to the board, things on time.

- **Project Management**

Lead Consultant decides on the Scope, Objectives and timeframes of the project following ISO/IEC 27001:2022. They allocate roles among the team members, keep an eye on the process, have to trouble shoot and micromanage any defects to ensure that the project is done on time. Lead Consultants guide the team on a course through responsible task management.

- **Quality Assurance of Deliverables**

An important remit of the Lead Consultant is to quality check all the deliverables – gap analysis, risk register, ISMS materials & presentations &etc, that it is accurate, it is complete, and that the works reflect what has been wanted. This is in compliance with iso 27001 guide, is compatible with another document or something may be a level of quality that is appropriate for executives. quality assurance dsm it (pvt) ltd is satisfied with the deliverables received from the consulting staff.

- **Board-Level Presentation and Recommendations**

The Lead AE is working on a board presentation, being given. That's the result of the gap analysis, risk and how you treat it, and with a small presentation of the strategic advantages of using ISO

27001. The complete ISMS and the wraparound of the results/report in language the board can read and understand are the 'value they added' and the 'work products' of the Lead Consultant.

Lead Consultant Facilitator: Support, supervision and lead on successful projects. With the strong and effective management and QA input, and also a strong link to senior management, the post is critical in leading DSM IT (Pvt) Ltd toward ISO 27001 and proactive information security resilience.

4.2) Risk & Controls Analyst

The Risk & Controls Analyst is a key player in the process of recognizing, monitoring, and mitigating risks in the ISMS implementation simulation DSM IT (Pvt) Ltd. This position is responsible for ensuring that the company's information security posture is measured, gaps are identified and adequate risk mitigation strategies are documented in compliance with ISO/IEC 27001:2022.

- Conducting Gap Analysis

The analyst starts by undertaking a gap analysis of DSM IT (Pvt) Ltd's existing security measures against those specified in ISO/IEC 27001:2022. This procedure will show which areas are in violation, what the current strengths are and how weak the system is. The results are used in setting risk management activities before ISMS is planned.

- Developing the Risk Register

From the gap analysis, the analyst develops a risk register documenting identified risks, threats and vulnerabilities, and affected assets. In risk management the risk is evaluated for probability and impact which helps the organization to rank the risks in order to rank the response to the risk. It is also a flexible tool to help make decisions and allocate resources.

- Designing Risk Treatment Strategies

The risks are then analyzed and ordered and the analyst produces the risk treatment plans. These can be as risk avoidance, reduction, sharing, or acceptance, depending on the requirements and the risk appetite of the organization. The analyst ensures treatment of plans align with, and provide support to DSM IT (Pvt) Ltd overall security objectives and controls (as per Annex A).

The Risk & Controls Analyst is responsible for DSM IT (Pvt) Ltd developing a clear view of our risks and implementing plans to handle them. This role is central to achieving ISO 27001 compliance and increasing the organization's resilience in information security through gap analysis, a structured risk register and treatment plans.

4.3) ISMS Documentation Specialist

The ISMS Documentation Specialist is responsible to prepare, compile and maintain all related documents (required documentation) for ISMS implementation in DSM IT (Pvt) Ltd.

Responsibilities of the role: Ensuring all documentation is (to the ISO standard, see below, and) audit ready.

- Drafting Core ISMS Documents

One of the main roles is to produce the required ISMS documentation such as the Statement of Scope, Information Security Policy, SoA (Statement of Applicability) and Risk Treatment Plan. They could be seen as the backbone of the ISMS and present the organisation with an information security model. The specialist is certain each document formalizes and provides succinct verbal grounding for readers and management.

- Ensuring ISO 27001 Alignment

All ISMS Documentation Specialist-created documents shall be subject of the relevant clauses and controls of ISO/IEC 27001:2022. This could involve delving into papers around Annex A controls and comparing those to the organisation's own risk register and treatment plan. In doing so, the consultant ensures DSM IT (Pvt) Ltd's ISMS organization is aligned with global benchmarks and is able to withstand third-party scrutiny.

- Managing Document Quality and Consistency

The specialist is responsible for version control and defines document style and structure for ISMS papers. Great to ensure correctness (don't duplicate stuff) and great for professional looking end-product you can present to board. It also makes it easier to continually update documentation as risks evolve or new compliance mandates are created.

The ISMS Documentation Specialist will ensure that all ISMS documents are in order and in accordance with the ISO/IEC 27001:2022 standard. ISMS The foundation for the activity The foundation on which ISMS deployed successfully, DSM IT (Pvt) Ltd operates with confidence and securing by using a well defined, trusted and audit acceptable security model.

4.4) Compliance Advisor

Compliance Advisor – Role responsible to ensure the ISMS Implementation exercise for DSM IT (Pvt) Ltd is in compliance with all relevant laws, regulations and agreements. This role is fundamental in supporting alignment of ISO/IEC 27001:2022 controls with external compliance obligations as well as vetting the recommendations of our consulting teams for industry and legal fit.

- Mapping Legal and Regulatory Obligations

Recognizes preconditions from industry laws, regulations, and standards on DSM IT (Pvt) Ltd. This may be through global laws such as GDPR or through country-specific data protection regulations such as PDPA in Sri Lanka. Clearing these accountabilities The Compliance Advisor enables the ISMS to focus on international requirements as an well local to avoid unnecessary penalties.

- Ensuring SoA Compliance

The Compliance Officer assists in formulating the Statement of Applicability (SoA) through noting evidence of its control from Annex A is applicable to the risks and legal requirements. They confirm that where applicable, all of the selected controls are in use and are not omitted without proper reason. This will leave the SoA being not just accurate, but defensible during an audit.

- Validating Recommendations and Risk Treatments

The Compliance Advisor collaborates with the Risk & Controls Analyst and Lead Consultant, in reviewing risk treatment plan and recommendations to ensure alignment with compliance obligation. They give revenant any holes, holes or inconsistency that rear, and in so doing guard DSM IT (Pvt) Ltd against acting unlawfully as well as against contract.

The Compliance Advisor provides a link between information security and regulatory compliance. Through the Visually representing the duties, accepting the SoA, and making suggestions that do not fall foul of the law, this role is facilitating further maturation of the DSM IT (Pvt) Ltd ISMS and strengthening the trust between the regulators, clients, and stakeholder.

4.5) Presentation & Stakeholder Engagement Lead

The Presentation & Stakeholder Engagement Lead must translate the findings of the consulting team into a professional and compelling board level presentation to DSM IT (Pvt) Ltd. This is a role requiring well thought through visuals, streamlined key messages and roleplays to simulate stakeholder interaction for executive level buy in of ISMS implementation.

- Developing the Board-Level Presentation

The role's main responsibility will be to create a 10-12 slide PowerPoint presentation outlining the consulting project. It contains the executive summary, gap analysis results, roadmap for implementation, risks identified, selected strategies for risk treatment, strategic business benefits of ISO/IEC 27001:2022. The Lead assures in the presentation the display of the most important insights provided in an impactful and concise way, which is reviewed with the senior management.

- Preparing Visuals and Roadmaps

For complicated data so that it is easy for the clients to understand the Presentation Lead creates an information visualization through charts, graphs, infographics, and time-lines. This creates clarity together with further understanding on technical and risk interpretations for relevant stakeholders. A particular focus will be to develop a project plan which states phases, priorities and time scales relevant to the implementation of the ISMS within DSM IT (Pvt) Ltd.

- Simulating Stakeholder Engagement and Q&A

Beyond slide creation, it is also the head of the preparation for engagement with executives, in terms of anticipating the questions and concerns of the decision maker. In partnership with the team, the Presentation Lead scripts real-world Q&A scenarios and receives exposure to confident, well-structured responses. This will prepare your team of consultants to overcome obstacles and provide strong reasons when they go in front of the board during the simulation.

The Presentation & Stakeholder Engagement Lead effectively communicates the consulting team's work in a clear and impactful manner. Through developing a professional presentation, assembling visuals and controlling the C-level presence, this role ensures the stakeholders have maximum confidence in the DSM IT (Pvt) Ltd's ISMS implementation journey.

5. Gap Analysis Report

5.1 Introduction to Gap Analysis

5.1.1 Purpose of the Gap Analysis

The gap analysis has the existence of ascertaining the current state of information security for DSM IT (Pvt) Ltd and determining the degree to which it meets the requirements of ISO/IEC 27001:2022." The analysis provides an official opinion of where the company is in relation to the standard and where the gaps, threats, or opportunities for improvement lie."

Strength and non-conformity identification through gap analysis provide a basis in planning to roll out an Information Security Management System (ISMS). It then enables DSM IT (Pvt) Ltd to prioritize corrective measures, manage risk in reality, and create a roadmap to ISO 27001 certification and enhanced information security resiliency.

5.1.2 Followed Methodology

Step-by-step gap analysis was carried out wherein organization's current practices were aligned with clauses (4–10) and Annex A controls of ISO/IEC 27001:2022. Steps adopted in the process were:

1. Document Review – Policies, procedures, and technical settings of information

security already in place were reviewed to ensure that requirements of the standard are met.

2. Interviews and Discussion – IT staff and stakeholders were interviewed in an attempt to further appreciate operational processes, issues, and ad hoc security measures in place.

3. Observation of Process – Standard information security processes such as access control and incident response were observed to determine reality of practice versus documented policy.

4. Gap Mapping – The identified practices were validated against ISO 27001 clauses and Annex A controls to identify conformance, partial implementation, or non-compliance areas.

5. Preliminary Risk Assessment – Assets, threats, and vulnerabilities were analyzed in order to assist in developing an initial risk register.

This method ensures findings to be evidence-based, comprehensive, and conformed to globally accepted best practice in information security management.

5.2 Overview of Current Information Security Posture

5.2.1 Organizational Context and IT Environment

DSM IT (Pvt) Ltd is a Software developing company offers wide range of services including Software development, IT Infrastructure support, Cloud based services etc. The company is competing in an environment where data privacy, system up-time, and regulatory compliance are critical to the public's trust in their product. Its IT ecosystem includes on-premises servers, cloud-based s ilion premises i d g e and a mix of enterprise applications and client web based offerings. Staff depend on digital communication, collaboration technology and remote access solutions – making information security a significant business priority.

5.2.2 Existing Security Policies, Procedures, and Controls

Currently DSM IT (Pvt) Ltd has put in place various basic information security controls in order to safeguard its business. These include:

- Simple Access Controls: Utilization of usernames and passwords for system entry, but restricted use of multi-factor authentication.
- Antivirus and Firewalls: Implementation of endpoint protection and network firewalls to lower the attack surface of the organization from malware and external threats.
- Backup & Disaster Recovery: Regular backups of business critical systems, however inconsistent recovery testing.
- User Awareness Education: A loose user training which includes educating users about phishing and safe IT practices.

- Physical Security: Limited access to server rooms and secure housing for key hardware components.

But, these people-based controls are still in active use and no integration with a more formal ISMS exists. Policies and guidelines are in draft or ad-hoc state not consistently documented, reviewed and enforced.

5.2.3 Current Strengths and Limitations in InfoSec Management

DSM IT (Pvt) LTD does have some strengths such as a proactive IT culture, an understanding of cyber security risk and investment in technical controls (firewalls and backups). Additionally, the company is supported by a skilled work force that can use sophisticated controls technology as the needs arise.

On the other hand, there are imposed restrictions. Policies not formally documented or existing as per baseline ISO/IEC 27001:2022 standards. Risk control is weak and there is no integrated risk register or risk plan. Both accessibility to and active monitoring of incidents are limited, with reports produced primarily by hand rather than telemetry. Furthermore no systematic evaluation has been carried out with regard to compliance with external regulation and contractual obligations and there is the risk to the organization in terms of legal and reputation.

5.3 Mapping to ISO/IEC 27001:2022 Requirements

5.3.1 Clause-by-Clause Assessment (Clauses 4–10)

DSM IT (Pvt) Ltd was compared with the mandatory clauses of ISO/IEC 27001:2022. The findings state that some security fundamentals have been started by the company but it lacks a documented and formalized Information Security Management System (ISMS).

- Clause 4 – Organization Context: Internal and external context is understood but not formally documented or as per stakeholder expectations.
- Clause 5 – Leadership: Security activity is supported by senior management, yet organizational duties and roles are not formally documented, nor is there a formally documented information security policy.
- Clause 6 – Planning: The risk register or treatment plan is not formally documented by the organization. Information security goals are not formally established.
- Clause 7 – Support: There is awareness but in an ad hoc manner, without competency development processes, communication, and documentation.
- Clause 8 – Operation: Regular security practice is being implemented but not in the name of managed standard ISMS processes.
- Clause 9 – Performance Evaluation: No systematic management monitoring, auditing, or review has been carried out.
- Clause 10 – Improvement: Reactive correction of improvements rather than planned corrective action or ongoing improvement.

5.3.2 Annex A Controls Assessment (A.5 to A.8)

Annex A controls provide technical and organizational security in good depth. DSM IT (Pvt) Ltd does attempt some early stages but remains considerably underdeveloped in formal compliance as a whole.

- A.5 – Organizational Controls: There are some draft security policies but not formally approved and rolled out.
- A.6 – People Controls: Unofficial worker awareness but absence thereof. No user or HR responsibilities-related security audits.
- A.7 – Physical Controls: Accessible from authorized persons but overall physical security is weak.
- A.8 – Technological Controls: Highly minimal controls like password protection and periodic backups but multi-factor authentication, encryption, and automatic monitoring are not present.

5.3.3 Areas of Compliance and Non-Compliance

- Areas of Compliance / Strength
 - o Basic access control (username and password).
 - o Normal backup of data.
 - o Locked access to the server room.
- Partial Compliance:

There are draft policies but not yet approved.

Patchy ad-hoc awareness.

There are technical controls in place but not as part of an ISMS.
- Non-Compliance:

There is no documentation of ISMS scope, risk register, and treatment plan.

noThere is no internal audit, monitoring, or improvement process.

noNo external legal or regulatory compliance mapping of.

noNo next-generation security controls (e.g., MFA, encryption, discovery automation) deployed.

5.4 Summary of Findings

Gap analysis on DSM IT (Pvt) Ltd The analysis on the gap on DSM IT private limited mentions some strength, partially aligned area & critical gaps multiply with ISO/IEC 27001:2022 requirements. This summary gives a brief overview of the organisation's current status related to information security, and indicates where there is room for improvement as part of the ISMS deployment.

5.4.1 Identified Non-Conformities

The gaps were identified with respect to the ISO 27001 clauses as follows.

- Lack of an explicitly defined ISMS scope which is being formalised/recorded.

- Lack of risk register and risk treatment plan in place.
- No approved corporate information security policies and procedures.
- There are no internal audits, monitoring or management review.
- Lax adoption of Annex A controls, a notable lack of controls in multi-factor authentication, encryption and automated monitoring for example.
- Lack of instrumentation of legal/regulatory/contractual requirements to ISMS controls.

5.4.2 Key Observations

A number of concerns to meet the ISO/IEC 27001 were identified:

- Security groundwork is there, but is mostly ad hoc, rather than codified.
- Employee-perception, non-routine and inconsistent, lack of training and awareness programs.
- There are few incident reporting or management channels, and no formal escalation or documenting process.
- Physical as well as technical control is in place but are not fully merged into an overall ISMS framework.
- There are security processes that fly under the radar, and lack clear ownership and responsibility.

5.4.3 Strengths

However, despite the deficiencies, DSM IT (Pvt) Ltd shows some appreciable strengths in its current InfoSec position:

- The services were locked down with basic access control mechanisms (username and password protection).
- Proper data backup procedures are in place to protect against loss of critical information.
- Only authorized personnel have physical access to server rooms.
- The org has a highly skilled technical team who are able to do deep work on security.
- Employees know there are security threats out there and it's growing so there is a base to build on for formal training programs.

5.5 Initial Risk Register

The first one is an IT risk register for DSM IT (Pvt) Ltd which lists their main assets, threats, associated vulnerabilities, and assesses the related risks by using the impact model. This register is the base for risk treatment strategies and relation between ISMS controls and ISO/IEC 27001:2022 standards.

5.5.1 Identified Assets, Threats and Vulnerabilities

The organization's critical assets and associated threats and vulnerabilities were evaluated as:

- IT services: systems and network administration, cloud and others
 - o Threats: Cyber-attacks, malware, unauthorized access
 - o Threats: Poor access management, lack of multi-factor authentication, obsolete programs
- Applications and Software Solutions
 - o Threats: Software exploitation, data loss “We did not have [adequate] plans to increase the protection around our IT systems.
 - o Weaknesses: Incomplete patch management, Little security testing
- Sensitive Client Data
 - o Risks: Stolen Data, Inadvertent Release, Ransomware Submission
 - o Weaknesses: Low encryption level, inadequate policies for data handling
- Employee Devices and Endpoints
 - o Threats: Malware infection, phishing attacks
 - o Vulnerabilities: In-poor-password policy, not-monitoring-endpoint
- Tangible Assets (server room, office equipment).
 - o Threats: Theft, natural disasters
 - o Weakness: Limited control of physical processes and poor environment monitoring

5.5.2 Risk Ratings (Likelihood × Impact)

Every risk was judged by likelihood and impact:

- High Risk: Probably will occur and would cause significant operational, financial or reputational harm.
- Moderate Risk: Likely event with moderate impact on operations or security posture.
- Low Risk: It is unlikely and would have minor impact if they did occur.

For example:

Unauthorized access of client data → High probability × High impact → High Risk

• Occasional minor downtime for system maintenance → Likelihood: Low x Impact: Medium → Risk: Low

5.5.3 Prioritization of Risks

Prioritized risks for DSM IT (Pvt) Ltd to allocate their resources efficiently:

- * High-Risk – Requires immediate action; very tight monitoring and control.
- * Medium level risk items – Will mitigate and monitor the planned, probability, or impact reduction.
- * Low: Routine practice to monitor by inspect, or periodically review, no immediate action is necessary.

This attention to priority is designed so the organisation can tackle risks in order of risk importance and will underpin both the Risk Treatment Plan and the ISMS strategy as a whole.

5.6 Risk Treatment Recommendations

Based upon the risk identification and the prioritization in the risk register - 1, the subsequent risk treatment options for DSM IT (Pvt) Ltd are proposed. The concepts will help minimise the potential risks, secure critical assets and be consistent with the business goals of the entity, meet the compliance requirements of ISO/IEC 27001:2022.

5.6.1 Proposed Treatment Strategies

Any of the four ways can address the mentioned type of interpolations.

- Avoid: Remove activities or processes that create a lot of risk for the organization.

Example: Stop using software not supported and possibly having security vulnerabilities.

- Reduce: Lower the risk according to its probability or loss.

Example: Use multi-factor authentication, encrypt sensitive data, and have endpoints automatically scanned.

- Transfer: Put the risk onto a third party, through measures like outsourcing or insurance.

Example: Store sensitive data on cloud service provider platforms who have strong security credentials.

- Accept: Accept low-level risks and track them with a wait-and-see attitude as long as they are within the risk tolerance level of the organization.

Example: Impacting only a small part of the system for scheduled maintenance.

5.6.2 A Recommended Controls for High Priority Risks

Annex A Controls proposed High risk items 6.2.1 Labelling 6.2.1.1 All unsound peas shall be derived from sound stock 6.2.1.2 An official certification label shall be attached to all consignments.

In order to adequately address High-priority risks, the following Annex A controls will need to be evaluated:

- A.5. 1 Information Security Policies Formalize and establish enterprise-wide security policies.
- A.6. 1 Security Policies Organisational Security Policy: Explicitly designate security responsibility.
- A.8. 1 Asset Management: Discover and index critical IT and data assets.
- A.9. 2 Access Control – use Multi factor Authentication, strong password policy, and role based access.
- A.12. 1 OpSec: Antivirus is a must, lockdown configurations, and leverage logging/monitoring.
- A.17. 1B(OPM 1 REV) Information Security Continuity Back Up, Disaster Recovery, and Business Continuity Develop backup, disaster recovery, and business continuity procedures.

5.6.3 Relevance to DSM IT (Pvt) Ltd Business Objective

Risk treatments proposed are rationalised to the organisational's strategic goals:

- Secure Client Information: Enhancing controls serves to establish trust and meet regulatory requirements.
- Strengthening Business Continuity: Risks are moderated, and minimized downtime and disruption are achieved.
- Support and Contribute to Business Growth: A developed ISMS lets the business to pursue new ventures and clients with confidence.
- Show Compliance with ISO 27001: Risk treatment to int'l standards will enhance credibility, market position.

By adopting these controls, DSM IT (Pvt) Ltd is able to diminish the exposure to information security risks and to prevent threats to reasonable levels and take measures for acceptable controls consistent with cost effective controls and compliance with other requirements.

6. ISMS Core Documentation Pack

6.1 Scope Statement

The Information Security Management System (ISMS) for DSM IT (Pvt) Ltd provides the structure to control information security risks and protect the company's most sensitive information. The scope of the ISMS defines the limits, coverage and areas of focus to achieve alignment with the requirements of ISO/IEC 27001:2022.

6.1.1 Definition of ISMS Boundaries

The scope of the ISMS includes all information assets, processes and systems that are utilized to deliver IT solutions and services by DSM IT (Pvt) Ltd. It covers physical and digital perimeters for both on-premises and cloud resources, enterprise applications, employee devices and data storage. The definition shall also include all of the organization's workers, whether they are staff, contractors, or third-party suppliers who have access to the organisation's information systems.

6.1.2 Included Processes, Assets, Locations, and Departments

- Processes: Software development, IT operations, cloud operations, support, maintenance, incidents, and BC.
- Assets: Servers, networking, software, databases, clients and endpoint devices for employees.
- Places: Head office, development centers and all other remote working locations provided / approved by the Company.

- Departments involved: IT operations, software development, client services, and support representatives who process sensitive info.

6.1.3 Exclusions and Rationale

Some processes or areas can be out of the scope of the ISMS if they do not pose IS risk or are not really addressed by the requirements and the objectives of ISO 27001. For example:

- Non-sensitive administration activities.
- Operations for which the external partner is solely responsible, but which is not under the direct control of DSM IT (Pvt) Ltd. (Contractual obligations typically would specify security responsibilities)

There is a rationale for these exclusions, to remain focused on the areas of the view with the most risk exposure and business impact.

6.1.4 Alignment with Organizational Objectives and Risk Appetite

The Scope of ISMS is compatible with DSM IT (Pvt) Ltd's objectives to secure client data, provide continuity of critical business services and to comply with laws and regulations. The boundaries established ensure that resources are effectively deployed to maintain the level of management of information security risks that is in line with the organization's appetite for such risks and its strategic and business objectives.

6.2 Information Security Policy

The Information Security Policy states DSM IT (Pvt) Ltd.'s pledge on the protection of their information assets and on the business/operational side for the paramount need - the preservation of the confidentiality, integrity, and availability of their information and information processing facilities against threats and vulnerabilities and related risks in accordance with the requirements of ISO/IEC 27001:2022 based standards. This policy forms the basis of the company's ISMS and helps provide direction to all employees, contractors and interested parties to ensure a secure information environment is maintained.

6.2.1 Purpose and Objectives

This policy is intended to:

- Protect against unauthorized access to or use of organization or client information.
- Establish a systematic process for evaluating and mitigating the information security risk.
- Contribute to business goals through secure operations and regulatory compliance.

The objectives include:

- Preserving information confidentiality, integrity and availability.
- Risk management is implemented effectively and consistently.
- To adhere to any applicable laws and regulations, contractual or other obligations.

6.2.2 Commitment From Top Management

DSM IT (Pvt) Ltd senior management is committed to the information security. Top management will:

- Provide adequate resources to support the implementation and maintenance of the ISMS.
- Imbibe security consciousness among all levels of staff in the company;
- Implement security policies that are regularly reviewed for effectiveness;

6.2.3 Information Security roles and responsibilities

- Senior Management: Endorse policies and allocate resources and monitor the success of the ISMS.

Information Security Officer / ISMS Team The ISMS team is responsible for Establishing and reviewing the controls Monitoring compliance and reporting information security incidents.

- All Employees and Contractors to, follow security rules, report information security incidents and to be aware and to adopt secure behaviours in their work.

6.2.4 High Level Principles Security and Compliance Requirements

Manage security based on risk and proportional to the harm that could result if risk is realized.

Secure access controls, encryption and handling of sensitive data.

Comply with applicable legal or regulatory requirements, including PDPA and contractual requirements.

Drive continuous improvement of security procedures, controls, and awareness programs.

6.2.5 Implementation, Monitoring, and Improvement of Standards

A violation of this policy may result in disciplinary or remedial action, including the possibility of contract consequences.

This policy shall be reviewed annually, or in the event of significant change within the Vendor or technology.

The policy will provide for ongoing improvements to the ISMS based on regulations and feedback.

6.3 Statement of Applicability (SoA)

The Statement of Applicability (SoA) identifies what Annex A controls of ISO/IEC 27001:2022 are applicable to DSM IT (Pvt) Ltd, provides the justification for inclusion or exclusion, states implementation status, and maps each control to identified risks and relevant legal or regulatory requirements. The SoA also verifies that all controls chosen are in line with the organization's ISMS objectives and risk management context.

6.3.1 Selected Annex A Controls and Justification

•A.5.1 – Information Security Policies

- Inclusion Rationale: Establishes the foundation for information security management within the organization.
- Implementation Status: Draft policy developed; awaiting formal approval and dissemination.
- Mapped Risks/Regulations: Non-compliance with internal obligations; supports PDPA and client data protection obligations.

•A.6.1 – Organization of Information Security

- Inclusion Rationale: Determines roles and responsibilities for accountability and management.
- Implementation Status: Roles defined, but responsibilities not yet completely documented.
- Mapped Risks/Regulations: Minimizes risk of unauthorized access or misuse; supports contractual requirements.

•A.8.1 – Asset Management

- Inclusion Justification: All critical assets are inventoried, classified, and protected.
- Implementation Status: Asset inventory partially documented; classification scheme in progress.
- Mapped Risks/Regulations: Protects sensitive client information and key IT infrastructure.

•A.9.2 – Access Control

- Inclusion Justification: Limits access to information by business need and role.
- Implementation Status: Minimal username/password controls in place; multi-factor authentication projected.
- Mapped Risks/Regulations: Prevents unauthorized access; supports confidentiality requirements.
- A.12.1 – Operational Security
 - Inclusion Justification: Mitigates threats through secure operations and monitoring.
 - Implementation Status: Antivirus and firewalls established; automated monitoring not yet established.
 - Mapped Risks/Regulations: Reduces malware and network breach risks; aligns with ISO 27001 risk treatment objectives.
- A.17.1 – Information Security Continuity
 - Inclusion Justification: Ensures business continuity in case of disruptions.
 - Implementation Status: Backup processes in place; formal continuity plan under development.
 - Mapped Risks/Regulations: Minimizes operational downtime; complies with client contractual and regulatory demands.

6.3.2 Excluded Controls and Justification

Some Annex A controls are excluded due to limited applicability:

- Controls for high-risk physical locations outside ISMS scope – no impact on core IT operations.
- Industrial process controls not implemented by DSM IT (Pvt) Ltd – not applicable to service-oriented IT operations.

6.3.3 Mapping to Identified Risks and Regulations

All the selected controls address explicitly risks from the initial risk register, including unauthorized access, data breaches, operational downtime, and regulatory non-compliance. With their implementation, DSM IT (Pvt) Ltd ensures compliance of its risk treatment plan with legal/regulatory stipulations, e.g., PDPA and contractual agreements with clients.

6.4 Risk Treatment Plan

The Risk Treatment Plan provides an official approach by which DSM IT (Pvt) Ltd can treat and handle identified information security threats in the initial risk register. The plan prioritizes risks, decides on appropriate treatment actions, assigns responsibilities, and decides on mechanisms for

monitoring and reviewing effectiveness.

6.4.1 Prioritized Risks

- High-Priority Risks:

- Unauthorized access to sensitive client data
- Malware or ransomware attacks on IT infrastructure
- Loss of mission-critical business data during system crashes or accidental deletion
- Disruption of business during operation incidents

- Medium- and Low-Priority Risks:

- Minimum system downtime when it is maintained
- Non-critical process inefficiencies
- Low-impact threats with low visibility

6.4.2 Treatment Strategies Selected

- Avoid: Eliminate high-risk processes or unsupported application.

- Mitigate: Implement multi-factor authentication, encryption, firewall, endpoint monitoring, and secure settings.

- Transfer: Offload some data storage or processing to approved cloud providers.

- Accept: Monitor low-impact or low-probability risk without responsive action.

4.3 Timelines and Responsibilities

- IT Security Officer: Coordinate access controls and initiate mitigation steps – Timeline: 3 months

- Network Administrator: Install malware protection and monitoring tools – Timeline: 2 months

- IT Operations Manager: Coordinate backup procedure and data recovery – Timeline: 1 month

- Risk & Compliance Officer: Establish business continuity procedures – Timeline: 4 months

- IT Support Team: Coordinate low-priority risk and minor system maintenance – Ongoing

4.4 Monitoring, Review, and Effectiveness Evaluation

- Monitoring: Monitor the effectiveness of deployed controls, logs, and alerts.

- Review: Review quarterly the risk treatments and update the risk register.

- Effectiveness Evaluation: Track the effectiveness of treatment plans through KPIs, internal audits, and incident reports and improve as needed.

1. **Training and Awareness:** Making information security training mandatory for all employees and always ensuring that the employees understand the importance of adhering to the security measures.

This ISMS policy is updated periodically and when changes are observed on the security aspects of the company, threats and business strategic plans. For this reason, SK IT Solutions pays constant attention to information security so that its business will not be easily breached.



7. Roles and Responsibilities

RACI chart

The table below clarifies the responsibilities at each step using the RACI model, i.e.:

- R: Responsible
- A: Accountable
- C: Consulted
- I: Informed

Step	Information Security Manager	Risk Owners	Top Management
Establish the context	R	C	A
Risk identification	C	R	A
Risk analysis	C	R	A
Risk evaluation	C	R	A
Risk treatment	R	C	A
Management approval for residual risks	C	C	A/R
Monitor and Report	R	I	A
Regular Review	R	C	A

Project Manager

1. Introduction and Overview

Using of ISO 27001:2022 is important for SK IT Solutions to improve its information security system. Project manager is to make sure that project meets the time and cost requirement with proper coordination of the project with all the members. The following implementation will lead to development of an Information Security Management System (ISMS) that will help to secure the company's data and operations from security risks.

2. Key Responsibilities of the Project Manager

As the Project Manager, your responsibilities will be divided into three primary areas:

1. Project Planning and Timeline Management
2. Budget Oversight
3. Coordination and Communication Among Team Members

Each of these components ensures the successful implementation of ISO 27001:2022. [1]

3. Project Planning and Timeline Management

3.1 Creating a Project Plan

- Initial Assessment: First of all, one has to audits the current state of affairs of SK IT Solutions with regard to information security. This involve familiarization with the company's current policies and practice, an inventory of its assets as well as consultation to determine areas of nonconformity to the ISO 27001 requirements.

- Defining the Scope: Maturity should be focused on the aspects that are most important to the success of the organisation. For SK IT Solutions this will involve IT systems, application development, customer information and internal networks.
- Timeline Creation: Develop a detailed timeline, including key milestones such as:
 - Initial ISO 27001 Gap Analysis
 - Risk Assessment Completion
 - ISMS Policy Development
 - Risk Treatment Plan
 - Security Awareness and Training Initiatives
 - Compliance Audits
 - Final Implementation
- Task Assignment: Every group member should be assigned with specific tasks which would complement the general goals of implementing ISO 27001. Some of your responsibilities include co-operating with Risk Assessment Lead, ISMS Policy Developer, Implementation and Compliance Officer, Security Awareness Coordinator to ensure that all tasks are done within the stipulated time.

3.2 Monitoring Progress

- Weekly Progress Meetings: Maintain a meeting frequency with the convened group members as often as is necessary to report on the next steps and also on the possible hurdles to the project's progress.
- Progress Reports: Complete specific tasks each week and note all the activities that have been achieved, the remaining tasks that are yet to be accomplished along with the any likely problems that may affect the operations of the project. These reports will also be beneficial to all the stakeholders.

3.3 Adjusting the Plan

- Risk Mitigation: When faced with challenges or other impediments that may slow down the project, dynamically adapt to changes this is also referred to as project sleight of hand. For instance, if the Risk Assessment Lead faces challenges, you may require to redirect resources in order to maintain the project on course.

4. Budget Oversight

Managing the project budget is a critical responsibility of the Project Manager. The budget for the ISO 27001 implementation should cover:

- **Software and Tools:** Ensure the necessary software for risk assessments, documentation, and monitoring is available.
- **Training Programs:** Sensitize the employees on the changes through conducting orientation in new security policies and procedures to be implemented.
- **Compliance Audits:** Allocate adequate funds for engaging third-party auditors to come in and ensure compliance to the ISO 27001 regulation.
- **Incident Management Tools:** Make sure that instruments for management of response to incidents, risks, and business continuity are included in the budget.

4.1 Resource Allocation

- **Resource Planning:** Knowing how many resources are needed during each state of the project. These include, working manpower, external expertise if required, software acquisition and training of people.
- **Cost Monitoring:** Record the true costs in relation to the cost estimates. Managing, for instance through the use of project management tools like keeping track of expenses for the projects to avoid going over budget. [2]

5. Coordination and Communication Among Team Members

A key factor in ISO 27001:2022 implementation is that the matter is in some way ongoing at the company and involves many team members who each have a specific position. In this case, you have to carefully coordinate yourself based on the various roles within the framework of Project Manager as shown below.

5.1 Coordinating Team Members

- **Role Clarification:** Clearly define each team member's role and responsibilities, ensuring there is no overlap or confusion.
 - The Risk Assessment Lead will handle risk analysis and management.
 - The ISMS Policy Developer will draft the necessary policies in line with ISO 27001 standards.
 - The Implementation and Compliance Officer will focus on executing the ISMS and ensuring compliance.

- The Security Awareness Coordinator will focus on educating the employees and staff.

5.2 Regular Updates

- Daily Updates: Incorporate a system of mass reach daily correspondence (email or instant messaging) to inform the team of change or updates.
- Conflict Resolution: Handle any problems that may occur between team members quickly and make sure that such problems do not have a negative impact on the whole project.

5.3 Documentation

- Project Documentation: All documentation regarding project progress, decisions, and issues should be stored securely and made accessible to all team members. This includes:
 - Project plan and timelines
 - Budget reports
 - Risk assessments
 - Implementation procedures and documentation
 - Compliance checklists [3]

6. Creating and Maintaining Project Plans and Reports

6.1 Project Plans

Formulate project matrices that detail out the life cycle of the ISO 27001/ISMS project which will include the assessment phase, the implementation phase, and compliance audit. When it comes to the kind of tools and techniques, one should utilize the project management software including the Microsoft Project, Trello or Jira to manage the tasks and timelines pertaining to the particular project on hand.

6.2 Status Reports

- Weekly Reports: Compile weekly status reports to track the project's progress, including any deviations from the schedule or budget.
- Final Report: Upon completion, submit a final report that details the entire implementation process, including lessons learned, challenges faced, and recommendations for maintaining compliance.

6.3 Stakeholder Communication

- Client Communication: Regularly communicate with SK IT Solutions' leadership to update them on the project's progress. Present the project plan, and ensure they are involved in major decision-making steps.
- Audit Preparation: Ensure all documentation is prepared for the external auditors who will certify ISO 27001 compliance. [4]

Risk Assessment Lead

The Risk Assessment Lead has an important responsibility when it comes to the establishment of ISO 27001:2022 in an IT company. This position is expected to discover and evaluate opportune threats and risks that endanger the organization's information, do risk evaluations, and provide good risk management solutions. This role in the context of an IT company involves having knowledge of the principles of information security and the technological environment in the company.

2. Responsibilities

2.1 Identify and Value of Information Assets

- Department managers and asset owners and managers for defining and documenting all information assets
- Determine the extent of each asset's worth in terms of the organisation's functionality in case it is threatened
- Keep an updated record of information that is owned, in order to record the inventory on assets such as the hardware, software, data and other forms of intellectual property.

2.2 Threats and Vulnerability Analysis

- Determine threats that can affect the information in an organization with regards to internal and external environments
- A proper assessment of the organization's attackers should be done using suitable tools and procedures on a periodic basis.
- Also, keep up to date with threats and risks especially as they affect the IT sector.
- Examine the consequences of possible threats and risks on the company's assets

2. 3 Risk Assessment Methodology

- Design and apply optimum risk assessment procedure meeting the standard of ISO 27001:2022.
- What is more, guarantee that the chosen methodology is suitable within the IT company's context and risks intensity.
- This is due to the fact that the risk assessment methodology should be reviewed and updated from time to time. [5]

2. 4 Risk Assessments Should be Carried out on a Routine Basis

- Coordinate the programmes that involve risk analysis in all departments and structures
- Consult with relevant stakeholders in order to obtain all the required information and intelligence.
- Risk assessment and risk evaluation of the risks identified should therefore be assessed on their probability of occurrence and their severity of impact.
- Categorize risks based to their respective importance in the organisation

2. 5 Risk Treatment Planning

- Formulate risk management strategies for the risks that have been envisaged with regards to the various risk treatment principles such as risk prevention, transfer, acceptance and/or exclusion.
- Risk treatment: Consult with the other departments to identify the right approach that should be followed on the identified risks
- Make sure risk treatment plans are compatible to the organization risk tolerance and appetite
- Suggest ways through which the identified risks could be managed economically by proposing appropriate security controls and measures. [6]

2. 6 Reporting and Communication

- Risk assessment reports that contain elaborative information are necessary to be provided to the management and the other interested parties
- Express risks otherwise hard to explain to both, technical and non-technical stakeholders
- Inform the organisation's risk profile and the efficiency of the risk management responses regularly

2. 7 Causal Monitoring & Evaluation

- Main Requirements Supporting Periodic Risk Monitoring and Communication of Own Control Effectiveness
- This should involve the periodical evaluation of the risk assessment process as well as of the results.
- Risk assessment is to be updated based on drastic alterations in the organization and its surroundings.

3. Conducting Risk Assessments

3.1 Risk Assessment Methodology

- Create and execute the viable risk assessment procedure consistent with the ISO 27001:2022 guidelines.
- Choose the methodology that will be suitable to the context of the IT company and its associated risks.
- It is also important to periodically revise and improve the risk assessment process that is being used.

3. 2 Risk Assessment Process

- Cook up and implement thorough risks that cut across all departments of the organization and all systems.
- Contact relevant stakeholders to collect relevant information and intelligence
- Identify the risks with a view of establishing the possibility of their occurrence and their consequences.
- It is crucial to bear in mind both the assessment of numerical and non-numerical risks

3. 3 Risk Evaluation

- However risk is expressed as the product of threat likelihood and potential impact levels.
- Rank risks according to the impact they have or may have on an organization
- Assess the levels of risk as identified against the set risk acceptance criteria of the organization [7]

3. 4 DISTINCT FORMS OF IT RISK CONSIDERATIONS

- Evaluate risks associated with new generation technologies such as, cloud computing, AI, IoT.
- Assess the risks when it comes to development processes of software and the security of their applications.
- There are certain risks like risks concerning data centers, network, and while working remotely.
- Identify contingent situations concerning data protection and privacy regulations such as GDPR or CCPA.
- Assess Third-party and supply chain threats

3. 5 Risk Assessment Reporting

- Produce risk assessment reports that outline the risks faced to ensure all managers and appropriate stakeholder understand them well.
- Express risk concepts in a simple manner and translate them into forms that both technical and none technical people can understand
- Do periodic updates of the organisation's risk position

4. Developing Risk Treatment Plans

4.1 Risk Treatment Options

- For each identified risk, consider appropriate treatment options:For each identified risk, consider appropriate treatment options:
- Risk mitigation: Some of the ways to another level to minimize risk comprise the following:
- Risk transfer: Offloading (transferring of risk to third parties like for instance insurance companies).
- Risk acceptance: Bearing in mind, the following are the guidelines that had informed this study when addressing risks as acceptable within certain limits:
- Risk avoidance: Minimizing risks, which is a case of doing away with the risk factor or, in this case, the source.

4. 2 Control Selection

- Determine the most Suitable Security Control based to the ISO27001:2022 Standard's Annex A
- Make sure that specific controls justified and are commensurate to the risks identified in the assessment

- It should be both technical and organizational kind of controls.

4. 3 Development of Risk Treatment Plans

- Risk treatment plans: The probability, impact and risk description for each risk planned in detail
- Consult departments that have vested interest in the risk to offer an opportunity for finding out what course of action is most suitable when handling risks.
- Make sure that risk treatment plans are within the company's acceptable risk tolerance limit and risk aspiration.
- The actions required to treat the risks should therefore be prioritized according to the level of risks and resources available.

4. 4 Implementation Planning

- Describe particular courses of action, accountabilities, and timeframes for risk treatments
- Assess the costs of resourcing and allocate possible budget, necessary number of employees, needed technology for every treatment action
- It is therefore necessary to come up with performance indicators that could be used to evaluate the effectiveness of risk treatments.

4. 5 Residual Risk Assessment

- Assess the residual risk that is expected once the planned treatment has been accomplished.
- It is also important to make sure that conspicuous residual risks do not contradict acceptable levels set by the organization.
- Look at risks that may need to undergo further handling or warrant management acknowledgment. [8]

4.6 Continuous Monitoring and Review

- Incorporate measures that provide for the regular review of risks and the control measures put in place.
- Necessary revisions of the risk treatment plans also imply that one should perform recurrent assessments of the risk treatment plans and their results
- Modify risk management policies and interventions to reflect major shifts in the organisation or its setting

5. Skills and Qualifications

- Good knowledge of concepts of information security, regulatory requirements, and standards
- Familiarization with various requirements of ISO 27001:2022 and the processes of its implementation
- Product knowledge in risk assessment approaches and instruments
- Knowledge of the existing IT systems, as well as the information technologies that are being developed.
- Good problem analysis skills especially in the use of analytic tools.
- A very strong area was stakeholder management and their communication skills
- Certifications related to specific field like, CISM, CRISC, CISSP

ISMS Policy and Procedure Developer

The ISMS Policy and Procedure Developer is responsible for creating and maintaining the organization's Information Security Management System (ISMS) policy and supporting procedures in accordance with ISO 27001:2022 standards. This role requires a deep understanding of the standard's requirements and the ability to translate them into practical guidelines for the organization. [9]

1. Conduct a Gap Analysis

1.1 Review of Existing Documentation

- Catalog all existing information security policies, procedures, and guidelines
- Assess the current state of information security documentation against ISO 27001:2022 requirements
- Identify areas where existing documentation is insufficient or outdated

1.2 Assessment of Current Practices

- Evaluate actual information security practices across all departments
- Compare current practices with ISO 27001:2022 requirements
- Identify discrepancies between documented procedures and actual practices

1.3 Stakeholder Interviews

- Conduct interviews with key personnel from various departments
- Gather insights on current security practices, challenges, and areas for improvement
- Assess the level of awareness and understanding of information security principles among staff

1.4 Technical Infrastructure Review

- Assess the current IT infrastructure, including hardware, software, and network configurations
- Evaluate existing security controls and their effectiveness
- Identify potential vulnerabilities and areas requiring technical improvements

1.5 Gap Analysis Report

- Compile findings into a comprehensive report
- Clearly outline areas of compliance and non-compliance with ISO 27001:2022
- Provide recommendations for addressing identified gaps [10]

2. The following are the sub processes involved in the Development of ISMS Policy:

2.1 ISMS Policy Development

- Develop the primary ISMS organizational policy
- Make the documentation compliance to the requirements of ISO 27001:2022
- More than anything else, they must ensure that the organisation's commitment to protect information as an asset is well communicated.
- Aim the policy at the achievement of the organisation's aims and objectives

2. 2 Supporting Procedures Creation

- Specific activities should be set for each of the control mentioned in Annex A in the ISO 27001:2022.
- Customize the approaches to the general setting of the IT company
- It should be stressed that procedures need to be realistic and feasible and fulfil the key objective of preventing the risks that have been identified.
- Ensure that procedures reflect the strategic direction of the organisation and its attitude toward risk.

2. 3 IT-Specific Considerations

- Mitigate IT-inherent risks for instance, data loss, cyber terrorism, and software glitches
- Build guidelines and standards for software Secure coding practices, Cloud Computing Security, and Data security
- Some of the factors that should be included are; policies regarding protection of Intellectual property and Third Party Risk Management.

2. 4 Agile and Remote Work Adaptations

- This requires the designing of procedures that is flexible to the ever changing technological environment.
- The strategies should include formulation of policies that deals with the issues of remote work engagements [11]

2. 5 Relationship with Organizational Goals

- Reflect on the organisation's goals, mission, vision, and key success factors
- It is mandatory that all current policies and procedures implemented in an organization serve these strategic goals.
- Coordinate with the senior management in understanding business needs and incorporating them to the ISMS

3. The first is to Enhance Focus on Policy and Procedure Formation

3.1 Risk Assessment Integration

- Check the outcome of the organisation's risk evaluation
- Recognise high risk areas that may need attention in the near future
- Ensure that policy and procedures priorities correspond to the key risks and organizational goals and objectives [12]

3. 2 Compliance Requirements

- Take into account, there are any IT specific legal or regulatory standards.
- Ensure the business has policies and procedures in place especially when it comes to reporting mandatory compliance areas

3. 3 Resource Allocation

- Evaluate opportunities (time, human capital and financial resources) for policy formulation
- Establish a realistic time frame when it will be possible to come up with such policies and procedures considering the available resources.

3. 4 Quick Wins

- It's important to find out the areas that would benefit from improvements which can be easily done.
- These are the "quick win" policies that must be given special emphasis so that the momentum of change and the progress being made are evident.

3. 5 Dependency Mapping

- Record relationships between one policy or procedure to another
- Make proper conservative that basic policies are established before special ones.

4. Implement a Phased Roll-out

4.1 Roll-out Planning

- Consulting with Lipscomb, it is important to develop a phased implementation plan for the motivation plan.
- ‘High risk’ policies and procedures should be given first consideration when designing the roll-out process of management policies and procedures.
- Develop a plan that will involve the taking of time to implement all the policies in the organization.

4. 2 Pilot Implementation

- Choose department or team for initial or pilot application
- Introduce new policies on a trial basis to the organization and use them to experiment in the organization’s environment
- You would also like to collect opinions and revise accordingly before moving to the next stage of implementation.

4. 3 Communication Strategy

- Create a clear and detailed communication strategy to reach out to all the employees in regards to its new policies.
- There must be a heightened communication of this new policy through as many forums as possible within the organization to increase chances of awareness by employees.
- Always and specifically justify why new policies are out being formulated and why they would be a necessity to the organization

4. 4 Technical Implementation

- They should consult with the IT staff to put in place all the necessary technical measures that may be needed.
- Check that all systems are set and ready to support as well as enforce any new policies that would have been set.
- Assess tested technical controls for their efficiency [13]

4. 5 Documentation Distribution

- Centralise all documents that are related to the ISMS
- Make sure all your staff members have easy access to any policy or procedure you have put in place.
- Evidently, it may be dequeued with version control to properly manage the documents updates.

5. Regularly Review and Update

5.1 Scheduled Reviews

- Set a periodicity for the review of all and sundry policies and standard business procedures
- Review Everyone should provide at least an annual review or review after any major changes of the document.

5. 2 Change Management

- Enact structured changes as ways of updating policies and procedures Kelvin Muddan ft. places
- It is important that all the changes are well documented, approved for implementation, and communicated effectively.

5. 3 Audit Results Integration

- Integrate data that resulted from internal and external audits into policy analysis.
- This should be in a form whereby the audit results are used to determine aspects that require enhancement in the ISMS.

5. 4 Emerging Threat Monitoring

- Ensure that adopter is update with new and emerging security threats within the IT industry
- Who: Managers should periodically evaluate if there's a need to develop a new policy or amend existing ones because of new risk exposures.

5. 5 Regulatory Compliance

- Keep abreast with the developments of laws and regulations as they apply to the operations of the company.
- The last course of action is updating policies and procedures once needed to keep abreast of the changes and reach the state of compliance. (6)

5. 6 Continuous Improvement

- Encourage the people working on information security to embark on further improvement processes as a way of enhancing their practices.
- Promote creativity in security measures and in policies' conception
- Compare your X's frequency against the benchmark set by other industries and change accordingly

5. 7 Reorientation to align with Organizational Aims

- The last lesson is to check on the organization's goals and objectives that might be changing from time to time.
- This therefore means that the ISMS has to be maintained in a manner that it supports and is in line with these goals.

- Ensure that there are changes that are made to the policies and procedures in order to achieve the right balance.

Implementation and Compliance Officer

Being an Implementation and Compliance Officer, you stand as an essential figure in the spreading and constant check for the effective application of the Information Security Management System (ISMS) in relation to ISO 27001:2022 for SK IT Solutions. Some of the duties include making of implementation schedule, assessing compliance, and keeping records of all documents that are required for monitoring and auditing as well as future improvements.

1. Every implemented management system has an implementation plan, so does the ISMS. ISO 27001:2022 is a framework that is divided into multiple phases and therefore there is a need to ensure that all employees of the organization know how it will be implemented. This means that your work involves developing an implementation plan that will aim at outlining the sequence of activities that make up the ISMS along with associated timelines. Such a plan also needs to include human resources, technological and financial requirements of the endeavour. [14]

Key Elements of the Plan:

- **Phased Approach:** Implementation of the ISMS has to be split by phases concept (for example risk estimation, security measures development, validation, compliance with norms and standards, etc.).
- **Task Assignment:** Introduce accountability for the different sub-team members for each stage so that the roles are well understood.
- **Resource Allocation:** It is equally important to remember that for each phase you engage in, the correct resources which include human, technical and financial should be used.
- **Timeline Development:** Based on the above, it is important to create the following program evaluation review timeline:

1. **Risk Management:** Make sure consistency with the risk treatment process, which has been produced during risk evaluation phase.

2. **Supervising Conformity with Iso 27001:2022 Standards**

Therefore, following the establishment of the ISMS, it is requisite to monitor compliance on an ongoing basis. This involves a consistent Check on the controls, policies and procedures put in place with a view of ascertaining that they conform with the ISO 27001:2022 standard.

Key Tasks:

- Internal Audits: Conduct periodic internal inspections for the purpose of confirming that security controls started and running effectively.
- Compliance Tracking: Emergency – Develop a compliance tracking system, whereby any discrepancies or issue of non-compliance would be recorded in addition to the status of their handling.
- Gap Analysis: Conduct gap assessments at least annually to determine how the ISMS may not be fully realizing the requirements of ISO 27001:2022 and then make changes as needed.
- Incident Reporting: Make sure that all security occurrences are reported as per the incident handling plan and should also be documented, evaluated and utilized in enhancing security.
- Review of Legal and Regulatory Requirements: This process should involve frequent references to the legal and regulatory framework and the identification of the changes made as a way of facilitating updating of the ISMS whenever the laws are changed. [15]

3. Maintaining Necessary Documentation

Of immense value to organizations that implement ISO 27001:2022 is arrangement and maintenance of comprehensive and accurate documentation which is a practical necessity in the actual running of the business and in audits.

Essential Documentation:

- ISMS Policy Documentation: It is crucial to make sure that all the current policies, including the data protection policy, access control policy and others correspond to the present ISO 27001 requirements.
- Risk Assessment and Treatment Records: Keep traceable records of all the risk evaluations done and challenging risk management strategies which relate to them. These documents have to be revised from time to time depending on threats whether they are new or they have evolved.
- Incident Logs and Response Plans: Make sure that all the security incidents are recorded and the incident handling team acts according to the outlined procedure.
- Audit Reports: With regard to records it is required to maintain the records of internal and external audit, and action plan for addressing all defaults.
- Change Control Documentation: That is where it is essential to have a change management process in place to document and approve any changes to the system or a policy. [16]

4. Continual Improvement Process

If you are to sustain the compliance aspect and upgrade the ISMS as time goes by, then you require to instill a continual improvement procedure. This is carrying out periodic assessments on the appropriateness of the ISMS with help from audits, incident report and performance assessment.

Improvement Methods:

- Management Review Meetings: Principle 10 – The organization shall review the ISMS on a regular basis and direct meetings with the senior management:
- KPIs: Record indexes containing data assembled about security occurrences, compliance deficiencies, and users' awareness to quantify effectiveness of the ISMS.
- Lessons Learned: Continues with the use of lessons learnt from previous occurrence and audits, in the future enhancements of the ISMS. [17]

Security Awareness and Training Coordinator

This role plays an important role in implementing ISO 27001:2022 for the Organization.

Security Awareness Program Development

Goals of the security awareness program

1. Educating Employees: The organizational information security policies, procedures, and best practices should be followed by all employees.
2. Security Culture: Develop a culture whereby security shall be everyone's concern, ensuring all threats that may arise are identified and minimized.
3. Human Error Reduction: Minimizing the chances of security breaches that depend on human factors through continuous education and awareness.
4. Incident Response Readiness: Providing knowledge and competencies to the employees in effectively responding to any kind of security incident will reduce damage and time required for recovery.
5. Protection of Organization Assets: Protect the confidentiality integrity availability of the organization's information assets by promoting the discipline of security.

Groups Receiving Training in ISO 27001:2022 Implementation

1. General Staff:

- To certify all employees understand basic information security principles and their role in protecting organizational assets.
- **Focus Areas:** Password management, recognizing phishing attempts, data handling procedures, and reporting security incidents.

2. IT Staff:

- Hands-on training in advanced knowledge and skills to maintain the security of the IT infrastructure of the organization.
- **Focus Areas:** Network security, system vulnerabilities, incident response, and compliance with security standards.

3. Management:

- To enable the management to appreciate its role in facilitating and enforcing information security policies.
- **Focus Areas:** Risk management, policy development, incident management, and fostering a security-aware culture.

4. Executives and Senior Leadership:

- Align information security imagination with the business objectives and validate senior management support for security measures.

Focus Areas: Strategic planning, regulatory compliance, resource allocation.

5. Third-Party Vendors and Contractors:

- Confirm with third-party vendors , contractors that they are aware of the security requirements of the organization.
- **Focus Areas:** Access control, data protection agreements, and secure communication practices.

Process for Creating Training Materials for ISO 27001:2022 Implementation

1. Needs Assessment:

- **Identify Training Needs:** Through organizational risk assessment and compliance requirements, identify topics of information security that must be addressed.

2. Audience Analysis:

Identify several groups within an organization and develop content that responds to the needs of each group with regard to prior knowledge.

3. Content Development:

- **Topic Selection:** Choose topics such as phishing, password management, data protection, incident response, and secure communication.

- **Drafting Materials:** Draft the training materials, including presentations, handouts, videos, and interactive modules.
- 4. **Review and Approval:**
 - **Internal Review:** The draft material is submitted for internal review by Experts to assure the material that is accurate and relevant.
 - **Compliance Check:** Certify all materials comply with ISO 27001:2022 requirements and any other regulations.
 - **Approval:** Obtain approval from management or the information security committee.
- 5. **Design and Production:**
 - **Visual Design:** Improve the materials with engaging visuals, infographics, and multimedia elements to improve understanding. [18]

Types of Training Materials

1. **E-Learning Modules:**
 - Interactive online courses that employees can complete at their own pace.
2. **Workshops:**
 - In-person or virtual sessions that provide hands-on training and group activities.
3. **Webinars:**
 - Live or recorded online seminars led by security experts.
4. **Printed Materials:**
 - Handouts, brochures, and posters distributed to employees.
5. **Videos:**
 - Short, engaging videos that illustrate key security concepts and scenarios.
6. **Interactive Simulations:**
 - Scenario-based simulations that allow employees to practice responding to security incidents.

Schedule for Regular Training Sessions and Refresher Courses

1. **Initial Training:**
 - **Frequency:** Upon hiring.
 - **Content:** Broad overview of information security policies, procedures, and best practices.
2. **Quarterly Refresher Courses:**
 - **Frequency:** Every three months.
 - **Content:** Updates on new security threats, changes in policies, and reinforcement of key security practices.
3. **Annual Comprehensive Training:**
 - **Frequency:** Once a year.
 - **Content:** In-depth review of all security policies, procedures, and incident response protocols.
4. **Ad-Hoc Training Sessions:**
 - **Frequency:** As needed, based on emerging threats or changes in regulations.

- **Content:** Focused training on specific issues or new security measures. [19]

Conducting Training Sessions

Training sessions for ISO 27001:2022 implementation will be designed to be engaging and effective. Here's how they will be conducted:

- **Interactive Elements:**
 - **Quizzes and Polls:** This will keep the participant interested and, at the same time, test the understanding of participants.
 - **Group Discussions:** To contribute their ideas and experiences.
- **Hands-On Activities:** Practical assignments designed to enable employees to apply the knowledge that they obtained.
- **Real-Life Scenarios:**
 - **Case Studies:** These provide scenarios of actual incidents where information security was breached, with discussions on how those could have been avoided.
 - **Role-Playing:** Employees will practice responding to security incidents by acting out scenarios.
 - **Simulations:** Run phishing simulation exercises to train employees in identifying such threats and acting accordingly.
- **Delivery Methods:**
 - **In-Person Workshops:** For more interactive and hands-on training.
 - **Webinars:** To reach remote employees and provide flexibility.
 - **E-Learning Modules:** Self-paced online courses that employees can complete at their convenience.

Communicating Security Policies and Updates

Effective communication of security policies and updates is crucial for maintaining a secure environment. Here are some methods:

- **Email Newsletters:**
 - **Regular Updates:** Sending out monthly newsletters with the latest security policies, tips, and updates.
- **Meetings**
 - **Regular Team Meetings:** Including a segment on security updates in regular team meetings.
- **Posters and Infographics:**
 - **Visual Reminders:** Placing posters and infographics around the office to reinforce key security practices.
- **Training Sessions:**
 - **Refresher Courses:** Frequently scheduled training sessions to keep employees updated on the latest security practices. [20]

Measuring the Effectiveness of the Training Program

Effectiveness of the training program will be measured using various methods.

- **Employee Participation Rates:**
 - **Attendance Records:** Record the number of employees attending each training session.
 - **Completion Rates:** track the percentage of completions of e-learning modules.
- **Quiz Scores:**
 - **Average Scores:** Check the average score of quizzes to compare general knowledge.
- **Improvement Rates:** Measure the improvement in scores from pre- and post-training quizzes.
- **Incident Reduction Rates:**
 - **Security Incident Reports:** Tracking the number and severity of security incidents compared to pre training.
 - **Phishing Simulation Results:** Monitor the response rate of employees in identifying and reporting simulated phishing attacks.
 - **Survey Responses:** Analyzing the response from surveys to understand employee engagement and satisfaction.

Monitoring and Reporting Compliance with ISO 27001:2022 Training Requirements

Recommendations for Ongoing Development and Improvement

1. **Regularly Update Training Content:**
 - **Stay Current:** Ensure training materials are updated to reflect new vulnerabilities and best practices.
 - **Incorporate Feedback:** Regularly collect the feedback of employees to improve training content.
2. **Enhance Engagement:**
 - **Gamification:** Make the training fun and entertaining by adding gamified elements.
 - **Interactive Tools:** Use more interactive tools and technologies to enhance learning experiences.
3. **Increase Accessibility:**
 - **Flexible Learning Options:** Provide various learning formats (mobile-friendly courses) to accommodate different learning preferences.
 - **Language Support:** Offer training materials in multiple languages to certify all employees can fully understand the content. [21]

6. Risk Management Framework

SK IT Solutions adopts a holistic Information Security Risk Management Framework that aims to identify, and assess information security risks for further effective control. The framework is fully developed and operational according to the principles and requirements of ISO 27001:2022 standards and it covers risk, risk assessment, risk treatment and risk monitoring. Stages in the process include the following aspects, however, limited to the following aspects:

Risk Identification: The institution periodically evaluates the extent of risk for information faced by its infrastructure. Such actions could involve the external front, cyber-attacks, viruses and other malevolent attacks whereas the internal one would involve information systems security threats from the on board staff members.

Risk Assessment: Since the risks were located, they are evaluated in terms of extent, probability of occurring, and their possible impact to the business. Like many companies, SK IT Solutions deploys a risk matrix method in the ranking of possible risks according to the emanating potential levels. The priorities were especially given to risks that are likely to endanger the crisis systems and crucial information.

Risk Treatment: Thereafter appropriate control measures Healthcare management undertake is put in practice ensuring efficiency in respect of the named risks. Control measures could be ‘hardware’ like encryption and multiple factor authentication, firewalls and access control or ‘software’ that includes policies and procedures among other things.

7. Document Control and Change Management

In order to preserve the efficacy, applicability, as well as the security of all records and documents of ISMS, SK IT Solutions has established a system of document control and change control. This process also involves appropriate records of changes made to the ISMS including approval and communication to relevant stakeholders and adherence to the regulations set by ISO 27001: 2022. The following controls are in place:

Version Control: Each and every The ISMS document bears a distinct and traceable version control number hatched on every and all modifications or updates done towards it. Each issuer statement version contains information about the writers, the date when the document was created or last revised and the recording of documents approval from authorized individuals. Version histories are kept and recorded up to provide a schedule to accommodate all the changes done to a particular document.

Review Process: Periodic review of the ISMS documentation are done apparently this is to look into any changes that need to be made as further modifications like change of risk environment,

technological changes, changes in laws and regulation etc. That regular reviews help in keeping security policies and procedures relevant and effective.

Amendments: Only qualified staff especially IT personnel employed as the ISMS Policy and Procedure Developer and management are empowered to undertake alterations of ISMS documents. Alterations made to any document are strictly put on the approval rule to ascertain their appropriateness, accuracy and conformity to the organization's objectives.

Change Management: Any ISMS related or aimed at the documents

8. Incident Management

SK IT Solutions has incorporated and formalized an Incident Management process into its ISMS which aids in establishing timely detection, reporting, and mitigation of security incidents. This process is meant to reduce the effects of incidents on business continuity and enhance the security of the organization over time. Important aspects of the incident management process include:

Incident Identification and Logging: Any information security breaches such as data loss, access by unauthorized persons, and hacking of systems must be reported immediately to the IT security officers. All employees are trained and instructed on the reporting of any incidents within the organization using the identified channels enabling early detection of incidents and subsequent corrective measures.

Incident Response Plan: An incident response plan is prepared to provide systematic management of incurring circumstances. The plan contains various aspects, and it is implemented in a series of steps which includes.

Containment: Measures are instituted to control the impact and reach of the incident.

Eradication: The factor that led to the incident is exposed and countered.

Recovery: Normal activities are resuming for the systems in question while keeping data and systems secure.

Lessons Observed: The attack is investigated to understand what can be perfected further to avoid obtaining similar threats in the future.

Post-Incident Critique: After each occurrence of Information Security incident and crisis management measures, a post-incident assessment is carried out in order to identify the cause of the problem and management measures

9. Audit and Compliance

SK IT Solutions is devoted to keeping the effectiveness and compliance of its ISMS via a robust Audit and Compliance technique. This ensures that all safety controls remain effective and that the corporation adheres to ISO 27001:2022 standards and other applicable legal and regulatory necessities. The audit and compliance manner includes the following:

Internal Audits: Regular internal audits of the ISMS are conducted as a minimum yearly by means of certified inner auditors or external consultants. These audits verify the implementation and effectiveness of the security controls, identifying any regions of non-conformity or ability risks to the ISMS.

Compliance Monitoring: Continuous tracking mechanisms are in region to ensure ongoing compliance with relevant criminal, regulatory, and contractual obligations. This includes adherence to frameworks consisting of GDPR, PCI DSS, and any enterprise-particular regulations that effect the business enterprise's information protection.

Corrective Actions: Any non-conformities or weaknesses identified throughout internal audits or through compliance tracking are addressed via a proper corrective movement procedure. This system ensures that the vital modifications are carried out to rectify issues and prevent recurrence, supporting future compliance with ISO 27001:2022.

By keeping this dependent technique to auditing and compliance, SK IT Solutions guarantees that its ISMS remains both effective and aligned with regulatory and commercial enterprise requirements

10. Continual Improvement

Continuous improvement is a fundamental principle of ISO 27001 and SK IT Solutions is committed to creating a structured process to ensure that ISMS remains effective and responsive to evolving security requirements. This process includes:

Regular Review and Updates: The Company will regularly review and update ISMS policies and procedures to reflect changes in the security landscape. business requirements and regulatory obligations These audits ensure that security controls remain consistent with the organization's objectives and risks.

Management Reviews: Management will conduct periodic reviews to evaluate the overall effectiveness of the ISMS. These reviews will evaluate the results of audits, events, and performance indicators. It identifies areas where ISMS can be improved.

Opportunity for improvement: Internal audit event report And employee feedback is a key resource in identifying opportunities for improvement. Companies use these insights to make data-driven decisions. This will help strengthen the ISMS and improve security practices.

Through a continuous improvement process, SK IT Solutions ensures that the ISMS is not only compliant with ISO 27001:2022, but also continuously updated to meet future challenges.

Risk Security Report

Introduction

Effective information security management is paramount for SK IT Solutions to reduce risk and protect its reputation in a competitive environment. This is despite the fact that the company has made great strides in managing security risks. But there is great value in continually improving and aligning our practices with industry standards.

The international standard for information security ISO/IEC 27001 was first published by the International Organization for Standardization (ISO) and the International Electrical Commission (IEC) in 2005 and was later revised in 2013. SK IT Solutions has decided to adopt ISO/IEC as a robust information security management system (ISMS) as a strategic framework for operations. This implementation will help ensure that our security goals are up to date and that our processes, policies and controls are continuously improved. SK IT Solutions also aims to achieve ISO certification. /IEC 27001, which verifies our commitment to information security best practices through an independent third-party assessment.

A key component of our ISMS is effective risk management. Risk in this context refers to the occurrence of an adverse event or failure to achieve a desired outcome. This can adversely affect business risks that occur when:

- Failure to meet business objectives: Failure to achieve strategic and operational goals.
- Asset Unsafe: Loss or damage to valuable information assets.
- Non-compliance: Non-compliance with organizational policies, procedures, external regulations.
- Inefficient use of resources: Mismanagement of resources that reduces efficiency and effectiveness.

To manage these risks effectively, SK IT Solutions will establish a comprehensive risk assessment and treatment process. This process is designed to prevent potential impacts from becoming actual threats and to ensure that appropriate contingencies are in place if risks do materialize. The process will be detailed and structured to produce consistent, valid, and comparable results across different assessments.

The selection of controls to address identified risks will be based on Annex A of ISO/IEC 27001, as well as additional controls from ISO/IEC 27017 and ISO/IEC 27018, which provide guidelines for cloud security and protection of personal data, respectively. This approach will

ensure a robust and comprehensive risk management framework that aligns with industry best practices.

1. Risk Assessment and Treatment Process

This document aims to facilitate similar Risk Assessment and Treatment based on the following international standards:

Information Security Management Systems in ISO/IEC 27001

ISO 31000 – Principles and guidelines on Risk management

These standards deliver authoritative guidance on information security management concepts, good practice, and procedures. Please advice to review thos documents to understand entirely the context where this risk assessment prosess work.

Risk Assessment and Treatment Process

Figure 1 The process for risk assessment and treatment is presented as part of the accompanying text as Results. It mostly uses quality risk harmonisation methods, addressing different terms to define the relative impact of each identified risk that most commonly are high, medium and low. In some cases, quantitative methods may be used, with quantities for example financial values being used to better measure the risk. All relevant criteria and rationale for the use of quantitatvie methods should be fully documented in order to make transparent and repeatable the risk assessment

1. Risk Identification

Purpose: To map all security risks within the organization of importance to information assets.

Method: Risks are identified in different ways: brainstorming, expert consultations and reviewing of historical incidents. This is all about finding the threats and vulnerabilities which can compromise confidentiality, integrity, and availability.

2. Risk Assessment

Requirements : The risks are rated depending upon their probability and impact. The assessment is not digital; the results have to be in buckets (high, medium, low), and dropdown lists are then generated based off risk category.

Methods for Evaluation: The risks are evaluated as per the risk matrices and impact scales. In more extreme circumstances, a quantitative approach could be taken to give you an exact figure (e.g. dollars/pounds/jingle-dangle units of finance moment activation or regression analysis)

3. Risk Treatment

Treat Identified Risks with Available Risk Treatment Options

Mitigation: Implementing controls or measures to prevent the occurrence of negative risks or their impacts.

Transfer: Transferring the risk to a third party like insurance.

Acceptance: The risk is within acceptable limits, and no additional controls are required.

Avoid: Modifying business processes or activities to take the risk away permanently.

4. Risk Monitoring and Review

Monitor: The risks identified and their treatments are monitored to validate that they have the intended effect, but also to identify changes in the risk environment.

Audit Process: Audits are built in to the regular review and updating process to ensure continued relevance of risk assessment. Here, reassessing of risks and treatment steps as threats/vulnerabilities change.

This comprehensive, systematic and integrated approach is designed to ensure that risk management for SK IT Solutions is in concert with best practices globally.

1.1 Criteria for Performing Information Security Risk Assessments

At SK IT Solutions, risk assessments are critical for ensuring the security and integrity of information assets. The criteria for performing information security risk assessments are designed to address various circumstances and changes within the organization. Risk assessments will be conducted under the following conditions:

Initial Implementation of ISMS: A risk analysis will be completed with the first implementation of the Information Security Management System (ISMS). A complete understanding of risks and vulnerabilities, will enable one to have a better grasp on them — this is possibly achieved from an all information assets assessment as a baseline.

Management Review Process: Modifications to the whole risk evaluation will be performed in the course of management review process. This review will refer to the maturity of assets, threats, vulnerabilities and hence perhaps risk levels so that the risk assessment in place is current (but must still be formally reviewed regularly by risk management governance process) and applicable.

Significant Organizational Changes: The organization must conduct risk assessments As major changes would affect the ISMS or its information assets. That means things like new projects, major system upgrades, or changes to the company structure.

IT Change Management Process: Whenever you are analyzing any changes that need to be brought in the IT infrastructure, risk assessment will be enforced so you can evaluate if those changes should be given a green signal and implemented. Use this to make sure changes cannot expose new risks or attack vectors.

Major External Changes: If major environmental changes occur where the enterprise operates – this can be in a changed law or would include mergers and acquisitions, the organization will perform risk assessment. This will also help to understand if any risk assessment must be changed because of the emerging external variables.

Supplier Evaluation and Selection: The danger is recognized when the client is making use of a provider or selects one for the deliverance of cloud services. Third-party services will be brought in compliance with security and are not introducing new risks.

In cases where there is uncertainty about whether a risk assessment is warranted, SK IT Solutions will adopt a precautionary approach and perform the assessment to ensure all potential risks are addressed.

1.2 Risk Acceptance Criteria

When it comes to specifying risk control measures, there is a possibility for managers at SK IT Solutions to accept given risks rather than putting in place controls. Risk acceptance is accurate approach, but it has to be applied not often and only in some situations. The decision regarding which risks should be accepted, or not accepted, should therefore strenuously be pre-established with references to well understood benchmarks.

Criteria for Accepting Risks

The criteria that can be adopted in accepting the risks may depend on many factors such as: the risk attitude of the organization, the financial status of the organization, the legal and regulatory requirements, the view of the top management; the type of asset or business area under consideration etc. It is recommended that these criteria are to be further explained to knowledgeable personnel and in certain cases with top management before carryout a risk assessment. It's also important that the discussion sets the criteria on when risks can be tolerated without any additional treatment.

The risk acceptance criteria may include the following situations:

- Cost of Control vs. Potential Loss: Risk might be assessed and accepted if the cost of efficient control to be put in place is perceived to be costly as compared to the loss that may occur in case of the risk. This criterion helps in implementing cost effective risk management and careful use of resources.

- **Expected Risk Reduction:** The risks may be tolerated if there are upcoming changes that are expected to occur within a short period (for example when changing technology, improving business processes or there is anticipation for new regulations) since these changes are likely to reduce or overcome the risk factors. This means that any temporally accepted risk is regularly accompanied by anticipated gains.
- **Defined Thresholds:** Risks may be tolerated if the level of risk is below a certain pre-decided level, which may be expressed in terms of risk level (e.g. low) or amount (e.g. monetary value). This threshold aids in categorization of such risks based on their impact and ensures that no risks exceeding the required limit are allowed.
- **Calculated Risk:** Risks may be taken up when they are understood to be of a high level, but the potential of the risk outweighs the accompanying risk. In such circumstances, risk is said to be calculated as the risk taken carries more positive benefits than adverse consequences. Experience of the author indicates that this is commonly done in situations of strategic decision making where decisions are characterized by high risks with equally huge benefits.

These acceptance criteria must be documented and integrated into the risk evaluation stage of the risk assessment process. This documentation ensures that risk acceptance decisions are made consistently and transparently, and that they align with the organization's overall risk management strategy.

2. Risk Identification and Analysis

At SK IT Solutions, risk assessment and management possess a structure that follows the requirements of the ISO/IEC 27001 and its associated risks about confidentiality, integrity, and availability of information are considered in the Information Security Management System. The issuance of the risk statement will include some of the following processes:

1. Risk Identification

- **Objective:** To examine and find the possible and potential or possible risks that impact the information assets that are controlled by SK IT Solutions. Such actions require an assessment of possible threats and vulnerabilities to the information security of the organization.
- **Approach:** The identification process will use the following approaches:
 - **Asset-Based Approach:** This approach is very detailed because it requires listing all information assets including hardware, software, data, and personnel, and performing risk analysis on them. It eases understanding of certain risks that exist with the different proportions of the ISMS.

- **Scenario-Based Approach:** This method is more abstract than the previous one and requires construction and research of situations or cases that could pose a danger to information security. It seeks to know what might happen in the organization and the effects of the particular events on the organization.

Both approaches are acceptable under ISO/IEC 27001 standards. The choice of approach may depend on the scope and complexity of the risk assessment.

2. Asset Inventory

- **Comprehensive Listing:** Create a comprehensive inventory of all information assets, including software, hardware, data, and personnel. This inventory serves as the foundation for identifying risks.
- **Categorization:** Classify assets based on their importance and sensitivity. This classification helps in prioritizing risk assessments and focusing on critical assets.

3. Threats and Vulnerabilities

- **Threat Identification:** Determine possible threats which may make use of the information assets' weaknesses. Common threats include hacking, phishing, malware, and insider threats.
- **Vulnerability Analysis:** Record any vulnerabilities that have been identified which may be exploited by the identified threats. For example, these can be outdated software, poor security measures and poor access management.

4. Risk Analysis

- **Risk Assessment:** Estimate the probability and consequences of identified factors causing losses. This assessment will employ risk scoring using qualitative methods, for example grading as high, medium, and low, and where applicable quantitative methods such as financial impact if relevant.
- **Risk Classification:** Group and put together the different risks that the organization is facing according to their level of severity and possible effect. This would assist in establishing the order of urgency in which the risk treatment actions would be undertaken.

5. Documentation and Review

- **Risk Register:** Prepare and keep all risks from throughout the institution's processes, together with their evaluation and risk management documents, they are all recorded in a risk register. There is likely to be such a risk register where any progress on the risk factors is captured and any additional risks that have been added or occurrences.

- **Ongoing Review:** The process by which new risks that have arisen are documented and the risk management strategies detailing how the new risks will be performed to achieve their objectives. Such risks will include re-evaluating the perceived risks and reassessing the risk within the asset inventory.

By following these steps, SK IT Solutions will ensure a systematic and comprehensive approach to identifying and analyzing risks, aligning with ISO/IEC 27001 standards and best practices.

2.1 Asset Inventory

At SK IT Solutions, a comprehensive inventory of assets is maintained to ensure all valuable assets are identified and protected. An asset is defined as "anything that has value to the organization" and warrants protection. This includes not only the data stored and processed by the company but also various other elements essential to the organization's operations.

1. Asset Definition and Types

- **Primary Assets:** The organization's central functions heavily rely on these elements, and they comprise of:
 - **Information:** All the information in SK IT Solutions including customer information, trade secrets, and other forms of intangible assets.
 - **Business Processes and Activities:** The processes and activities that are crucial for the day-to-day and long-term goals of the organization.
- **Supporting Assets:** These are essential for supporting primary assets and include:
 - **Hardware:** These are tangible items such as servers, desktop computers, and networking hardware.
 - **Software:** These pertain to business applications, operating systems, and other operational tools for the business.
 - **Network:** These include routers, switches, and other devices for communication.
 - **Personnel:** This refers to the management, operation, and support staff of information systems.
 - **Site:** Physical locations, including data centers and office spaces.
 - **Organization Structure:** The hierarchical and functional organization within SK IT Solutions.

2. Asset Inventory Management

- **Documentation:** The requirements for information life cycle management are achieved by employing an "Information Asset Inventory," which is considered a key element of

Information systems (ISMS). In the inventory, a complete scheme is given out that describes all assets, their worth and hold.

- **Asset Valuation:** Regarding each asset, a valuation is made regarding its uniqueness and confidentiality to the organization. This valuation is held at the time of doing an impact assessment in the entire management of risk process.
- **Ownership:** Every asset has a specific owner who has the authority over it and the procedures to safeguard it. Owners of assets participate in the factors that raise risks about the assets that they own. If relevant, cloud customer data will be owned by an internal organizational owner when and where cloud customer's asset value inputs are required.

3. Grouping of Assets

- **Asset Grouping:** Collectively categorizing assets because they have similar requirements attributes for risk assessment purposes. This method makes it easier in terms of scope and number of risks that need to be looked at, enhancing the overall risk assessment process.

Proper and systematic maintaining of the property database allows SK IT Solutions Company to track, identify, and manage all critical assets in compliance with the requirements of the ISO/IEC 27001 standard.

2.2 Threats and Vulnerabilities

As in the case with other activities within the ISO/IEC 27001 standard, threats and vulnerabilities identification is done with the assumption that information at SK IT Solutions is at risk of being compromised, modified or intentionally or accidentally destroyed within the Information Security Management System ISMS. This step is taken in such a manner that information assets exposure assessment and definition of the threshold for success of mission is followed through in a logical order.

1. Threat Identification

- **Goal:** To detect potential hazards that will be capable of taking advantage of existing weaknesses and detrimentally affect the information assets of the organization.
- **Approach:**
 - **Asset-Based Strategy:** This targeted strategy consists of determining the risks or threats that apply with respect to each of the assets in the Information Assets Inventory List held. For example, if a database server is one of the assets, its threats could include unauthorized use, information theft or destruction, malware installation etc.

- Scenario-Based Strategy: This is an overall or strategic type of approach whereby dependent scenarios which may threaten the security of information are formulated and evaluated. Scenarios that are evaluated include those of cyber-attacks, information sabotage, weather related disasters which all influence the organization.
- Common Threats:
 - Cyberattacks: Such as phishing, ransomware, and denial-of-service attacks.
 - Insider Threats: Employees or contractors who may intentionally or unintentionally compromise information security.
 - External Threats: Including hackers, competitors, or other malicious actors.
 - Natural Disasters: Events like floods, earthquakes, or fires that could disrupt operations or damage information assets.

2. Vulnerability Identification

- Objective: To pinpoint shortcomings in information systems and processes that can be utilized by the specified threats.
- Approach:
 - Asset-Based Approach: Recognize all the weaknesses that the given asset has, such as an old issue regarding untrusted computing applications could be due to known vulnerabilities while old hardware might still get stolen due to lack of physical security.
 - Scenario-Based Approach: Scrutinize the previously identified threat scenarios and realize what weaknesses could be leveraged within these scenarios. This might study how certain threat scenarios might be created which will exploit susceptibility of certain systems or processes to known threats.
- Common Vulnerabilities:
 - Software Vulnerabilities: It involves the use of software that is not up to date and lacks patches, hence can be compromised easily and used by malicious entities.
 - Weak Access Controls: Ineffective measures to validate and approve access rights to various entities.
 - Insecure Configurations: These are applications, operating systems, or information systems set in a manner that increases chances of attacks against them.

- Lack of Security Awareness: People within the organization do not have enough knowledge and education that requires them to perform security tasks that will control the incidences of human error related security threats.

3. Documentation and Review

- Risk Register: Include all existing threats and vulnerabilities in a risk register. Describe all the contents and actions for each entry in the register including description of a threat or vulnerability, its impact, and what assets are connected to it.
- Ongoing Review: Assess the threat and vulnerability identification process on an ongoing basis to address changes, new threats and new vulnerabilities.

In achieving these steps, it will be ensured that processes for the identification of threats and vulnerabilities will be streamlined at SK IT Solutions in line with the requirements and best practices on ISO/IEC 27001.

3. Risk Treatment Options

Organizations employing information technology are likely to encounter risks during their operations. Risk management in this case involves the identification of risks and the selection of subsidiaries among risk treatment options available. This facilitates achievement, minimizing the effects of disruption or other adverse happenings. Treatment options primary appropriate for this are:

1. Mitigation

- **Definition:** Putting measures that prevent or lessen the effect of the risks that have been identified.
- **Objective:** To reduce the risk, acceptability such that the risk-initiating event is prevented from happening or its consequence is decreased.
- **Examples:**
 - **Technical Controls:** Network firewall systems, secure socket layer and encryption services to prevent unauthorized access and information leakage.
 - **Procedural Controls:** Developing and enforcing policies and procedures, including training programs for employees and employee responsibilities regarding incident management.
 - **Physical Controls:** Adding physical security measures, such as screening access for data centers and sensitive areas.

2. Transfer

- **Definition:** Using a different person or company to manage the risk in question.
- **Objective:** To avoid being the risk bearer, assigning the risk to another party in general, by means of contract or insurable cover.
- **Examples:**
 - **Cyber Insurance:** Insurance policies that are bought that cover a company from the losses, which are likely to be incurred due to viruses or hacking.
 - **Outsourcing Services:** Engaging third-party vendors for critical services, where the vendor assumes responsibility for managing specific risks associated with their services.

3. Acceptance

- **Definition:** The process involves recognizing the risk and then deciding if such risks can be taken if it is within the risk appetite of the organization.
- **Objective:** To accept the risk under which controls are retained whenever the estimated costs of future damages are lower than the cost of the risk mitigation or when this whole risk situation is considered acceptable in the organization.
- **Examples:**
 - **Low-Impact Risks:** Certain risks that do not pose a high level of threat to the operations or the financial system of the organization may be adopted if the probabilities of a loss are low.
 - **Strategic Risks:** These are risks that may be tolerated as part of an organization's overall strategic strategy-optimization with risks before reaching the 'however' point.

Kaizen treatment for Supply Chain Business Area/Membership risks All the risk treatment options are subject to assessment in respect of their efficiency, price, and compatibility with KS IT Solutions risk management policy. The treatment measures are outlined in the risk register accompanying the project and the orientation is done periodically with the aim of enhancing the orientation of the institution towards risk management.

4. Risk Register

Overview

A risk register is an important document in the work of SK IT Solutions regarding prudently managing interactions with risks that have been recognized and analyzed. It keeps a complete record of all risks, their current status with treatments, and the activities undertaken for their management. The risk register facilitates systematic monitoring, control and review of all activities related to identified risks.

Components of the Risk Register

- **Risk Identification:** All risks that are likely to affect the information assets of the organization will be addressed and including the source of the risk in the risk registration and its potential effects.
- **Risk Assessment:** Established documented assessment of the risk and the magnitude of potential impact and probability of such risk occurrence including how it classified (e.g. high, medium, low).
- **Risk Treatment:** Descriptions of how the addressed risks will be minimized via the selected risk treatment strategies.
- **Responsibility:** Risk ownership including all individuals or teams in charge of implementing and/or supervising treatment actions towards the respective risk.
- **Status Updates:** Contingency planning requires timely information about the current risk status including and risk level, and treatment and control measures adopted, progress made and effectiveness.
- **Review Dates:** and set times when the risk registration and Risks will be renewed and updated and or the risk registration will be revised if necessary.

Maintenance and Review

The risk register is also to be revised on a regular basis, to include any changes that have taken place in the risk environment, the changes and development of some of the risks present, and changes regarding the courses of action to be undertaken. This process in ensuring that the risk register remains up to date within the risk management procedures of the organization.

Security Awareness and Training Plan

1. Program Delivery

- **Overview:** The security awareness program at SK IT Solutions shall be fashioned in such a way that employees will learn the basic information security policies and practices and be made aware of possible threats.
- **Methods:**
 - **Online Training:** Such e-learning modules are hence such that they are highly interactive, and most if not all of the employees will have easy access to them. All the fundamental aspects of security will be covered within the modules and will be done at the pace of the learner.
 - **Workshops:** The hands-on training is provided through face to face or virtual workshops conducted by subject matter experts and real-life scenarios.
 - **Email Campaigns:** Additional emails on various security issues and measures will be sent routinely along with the email campaign updates, moderation, prognosis, and other instructions to reinforce the principles of training in employees' lives.

2. Target Audience

- **Scope:** All employees of SK IT Solutions will undergo this program as this will make sure that everyone is aware of and adherent to the security policies.
- **Role-Specific Modules:**
 - **IT Staff:** Thorough training concerning the technical aspects of security and the response to threats shall be imparted, including handling incidents and thus threat mitigation.
 - **Administrative Staff:** Security awareness at the most basic level including data security and phishing identification.
 - **Other Roles:** Specific content for the specific roles which aims at specific security issues for those whose Job Description weight varies.

3. Evaluation Methods

- **Assessments:** The conducting of quizzes and tests at intervals after the training modules in order to ascertain the concepts of security learnt by employees.
- **Surveys:** Surveys that document the employee work-learn feedback concerning the degree of effectiveness of the delivered training and the perception of its need.

- **Audits:** Periodical evaluations and investigation concerning the security behavior of employees for compliance purposes. This involves the verification of policy enforcement with respect to security and assessment of lack of understanding.

The training and practice of information security should be oriented and re-directed more towards the individual needs of SK IT Solutions in terms of organizational development to uplift the security level within the crime.

Incident Response Plan

Purpose and Objectives

The Incident Response Plan (IRP) aims to ensure SK IT Solutions can respond promptly and effectively to any security incidents. The objectives are to:

- **Minimize Damage:** Quickly contain and mitigate the impact of security incidents to reduce harm to the organization.
- **Reduce Recovery Time:** Ensure that recovery processes are efficient and effective, allowing normal operations to resume as soon as possible.
- **Improve Preparedness:** Enhance the organization's readiness for handling future incidents by documenting lessons learned and refining response strategies.

Incident Response Team

The Incident Response Team (IRT) handles the response and coordination of all security threats and incidents. The IRT will comprise of:

- **IT Representatives:** To handle the technical side of the incident such as system breaches, malware and or a network.
- **Legal Representatives:** To take care of legal and other related issues, especially where relevant laws and regulations can be breached.
- **Management Representatives:** to supervise, act within the highest levels, and interact with stakeholders.

Incident Types and Response Phases

The IRP shall encapsulate number of types of incidents, though most of them are common:

- **Malware Attacks:** Spyware, viruses, ransomware or other types of hazardous software showing up as infections or threats.
- **Data Breaches:** The cyber theft of inappropriate or protected data committed by insiders or outsiders.

- **Cyberattacks:** outside blow such as the stopping of service through a simple DoS or port hacking.

Response Phases:

1. **Detection:** initiate and warranted detection of security incidents by means of monitoring systems and system report.
2. **Containment:** deploy quick actions that will keep the incident within limits and restrain any further adverse effects.
3. **Eradication:** terminate the order of the incident such as removing viruses or disabling a weakness in security.
4. **Recovery:** restore normal operations to affected systems and services while ensuring no remaining threats exist.
5. **Post-Incident Review:** Conduct a thorough review of the incident to assess its impact, effectiveness of the response, and update procedures to prevent recurrence.

Business Continuity Plan

Executive Summary

The Business Continuity Plan (BCP) has also been developed to provide SK IT Solutions with the ability to sustain and recover from crucial operations when they are disrupted or interrupted, for instance, by natural disasters, cyberattacks, or other emergencies. The primary goal of the plan is to safeguard the organization's capacity to offer vital goods and services in the course of and after a serious interruption.

Scope

The BCP encompasses the following critical components:

- **IT Infrastructure:** IT Infrastructure: Hardware and large-scale software systems to include servers, networks and other computer based tools necessary for the efficient conduct of business.
- **Customer Services:** Systems and activities associated with service provision and customer relationships management.
- **Data Centers:** These are facilities where only essential data and applications useful for the organization's business are located.

Business Impact Analysis

A Business Impact Analysis (BIA) will be conducted to:

- **Identify Critical Functions:** Identify the business activities that are critical to the continued functioning of the organization.
- **Assess Impact:** Analyze the extent of the effect an organization might suffer if one or more of these function(s) is derailed. Such effects may be financial, operational, or reputational among others.

Testing and Validation

The BCP will be examined in practice and appropriate measures taken on its usage on a regular basis. As part of the upholding of this standard, this includes:

- **Simulated Exercises:** There were simulations and drills to help strategize and practice response actions.
- **Plan Reviews:** Reviews which are time-bound and are aimed at verifying the accuracy of the Business Continuity Plan in relation to changes brought about by business processes, technology and the law.
- **Continuous Improvement:** Further adjustments to the BCP based on the lessons learned from drills, real-life events, and the behaviors of the industry going forward.

References

- [1] "hightable," hightable, [Online]. Available: <https://hightable.io/iso-27001-annex-a-5-8-information-security-in-project-management/>. [Accessed 05 09 2024].
- [2] "projecttimes," projecttimes, [Online]. Available: <https://www.projecttimes.com/articles/information-security-project-management/>. [Accessed 05 09 2024].
- [3] "anchor.ai," anchor.ai, [Online]. Available: <https://www.anchor.ai/blog/cybersecurity-project-management>. [Accessed 05 09 2024].
- [4] "threatintelligence," threatintelligence, [Online]. Available: <https://www.threatintelligence.com/blog/cybersecurity-project-management>. [Accessed 05 09 2024].
- [5] "IEEE xplore," IEEE xplore, [Online]. Available: <https://ieeexplore.ieee.org/document/9274574>. [Accessed 07 09 2024].
- [6] "IEEE explore," IEEE explore, [Online]. Available: <https://ieeexplore.ieee.org/document/8674294>. [Accessed 27 09 2024].
- [7] "IEEE explore," IEEE explore, [Online]. Available: <https://ieeexplore.ieee.org/document/9211066>. [Accessed 07 09 2024].
- [8] "IEEE explore," IEEE explore, [Online]. Available: <https://ieeexplore.ieee.org/document/9268845>. [Accessed 07 09 2024].
- [9] "droptica," droptica, [Online]. Available: <https://www.droptica.com/blog/iso-27001-it-company-what-do-implementation-and-benefits-look/>. [Accessed 10 09 2024].
- [10] "mdpi," mdpi, [Online]. Available: <https://www.mdpi.com/2071-1050/15/7/5828>. [Accessed 10 09 2024].
- [11] "ieeexplore," ieeexplore, [Online]. Available: <https://ieeexplore.ieee.org/document/7170355>. [Accessed 10 09 2024].

- [12] "emeraldinsight," emeraldinsight, [Online]. Available: <https://www.emerald.com/insight/content/doi/10.1108/TQM-09-2020-0202/full/html>. [Accessed 10 09 2024].
- [13] "IEEEExplore," IEEEExplore, [Online]. Available: <https://ieeexplore.ieee.org/document/6389395>. [Accessed 10 09 2024].
- [14] "cyber defense magazine," cyber defense magazine, [Online]. Available: <https://www.cyberdefensemagazine.com/compliance-in-cybersecurity/>. [Accessed 03 09 2024].
- [15] "dataguard," dataguard, [Online]. Available: <https://www.dataguard.co.uk/cyber-security/compliance/>. [Accessed 03 09 2024].
- [16] "nordlayer," nordlayer, [Online]. Available: <https://nordlayer.com/learn/regulatory-compliance/cybersecurity-compliance/>. [Accessed 01 09 2024].
- [17] "nternational Sharing University," nternational Sharing University, [Online]. Available: <https://sharingmetaeducation.org/enisa-profiles/cyber-legal-policy-compliance-officer/>. [Accessed 03 09 2024].
- [18] "itgovernance," itgovernance, [Online]. Available: <https://www.itgovernanceusa.com/blog/guide-to-iso-27001-security-awareness-training>. [Accessed 09 09 2024].
- [19] "mimecast," mimecast, [Online]. Available: <https://www.mimecast.com/content/what-is-security-awareness-training/>. [Accessed 09 09 2024].
- [20] "sciencedirect," sciencedirect, [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0167404821000912>. [Accessed 09 09 2024].
- [21] "isaca," isaca, [Online]. Available: <https://www.isaca.org/resources/isaca-journal/issues/2022/volume-3/better-cybersecurity-awareness-through-research>. [Accessed 09 09 2024].
- [22] [Online]. Available: <https://www.dataguard.co.uk/cyber-security/compliance/>. [Accessed 09 2024].